

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

«Обеспечение информационной безопасности мобильных устройств»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №2

«Основы анализа защищенности мобильных приложений»

Выполнили:

Жук Анастасия Валерьевна,
студент группы N3348


(подпись)

Проверил:

Федоров Иван Романович,
научный сотрудник, доцент ФБИТ

(отметка о выполнении)

(подпись)

Санкт-Петербург

2026 г.

СОДЕРЖАНИЕ

Введение.....	3
1 Сборка стенда.....	4
1.1 Установка VirtualBox	4
1.2 Установка GENYMOTION	4
1.3 Appie	9
1.4 Diva	10
2 Кейсы в Diva Android	14
2.1 Insecure Logging	16
2.2 Hardcoding issue part 1	19
2.3 Insecure Data Storage Part 1	22
2.4 Insecure Data Storage Part 2	26
2.5 Insecure Data Storage Part 3	30
2.6 Insecure Data Storage Part 4	33
2.7 Improper Input Validation Part 1.....	38
2.8 Improper Input Validation Part 2.....	42
2.9 Access Control Issue Part 1	44
2.10 Access Control Issue part 2	45
2.11 Access Control Issue Part 3.....	45
2.12 Hardcoding Issue Part 2.....	45
2.13 Input Validation Issue Part 3	45
Заключение.....	46
Список использованных источников.....	47

ВВЕДЕНИЕ

Цель работы – приобретение практических навыков анализа защищенности мобильных приложений платформы Android, освоение методологии тестирования на проникновение (pentesting) и изучение основных уязвимостей мобильных приложений согласно модели OWASP Mobile Top 10.

Для достижения поставленной цели необходимо решить следующие задачи:

- изучить теоретические основы безопасности мобильных приложений и модель OWASP Mobile Top 10 (основные риски и уязвимости);
- подготовить тестовый стенд для анализа защищенности Android-приложений;
- освоить базовые инструменты анализа мобильных приложений;
- провести практическое исследование уязвимостей на примере приложения Diva Android.

1 СБОРКА СТЕНДА

1.1 Установка VirtualBox

На первом этапе необходимо установить среду виртуализации VirtualBox, чтобы GENYMOTION мог создавать в ней виртуальные Android-устройства. У меня на ноутбуке уже был установлен VirtualBox, поэтому этот этап я пропустила.

1.2 Установка GENYMOTION

На рисунках 1 – 8 представлены процессы регистрации и входа в приложение Genymotion.

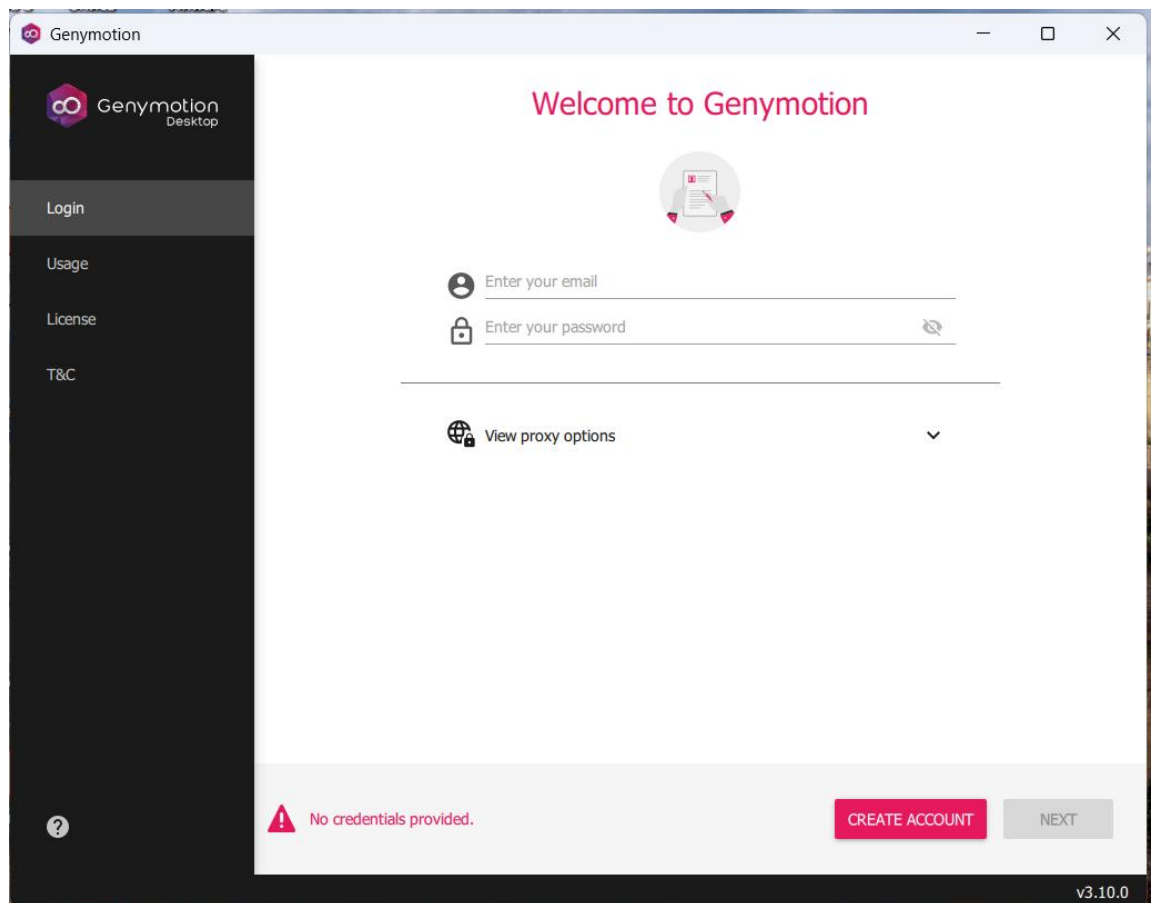


Рисунок 1 – Окно авторизации Genymotion

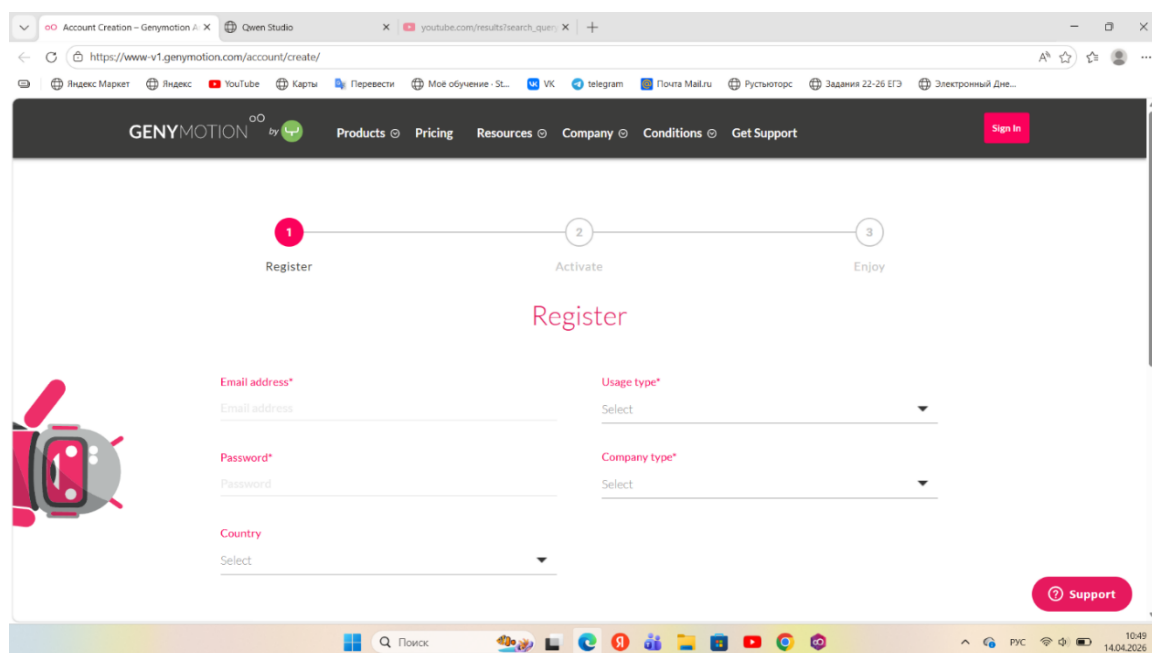


Рисунок 2 – Форма регистрации

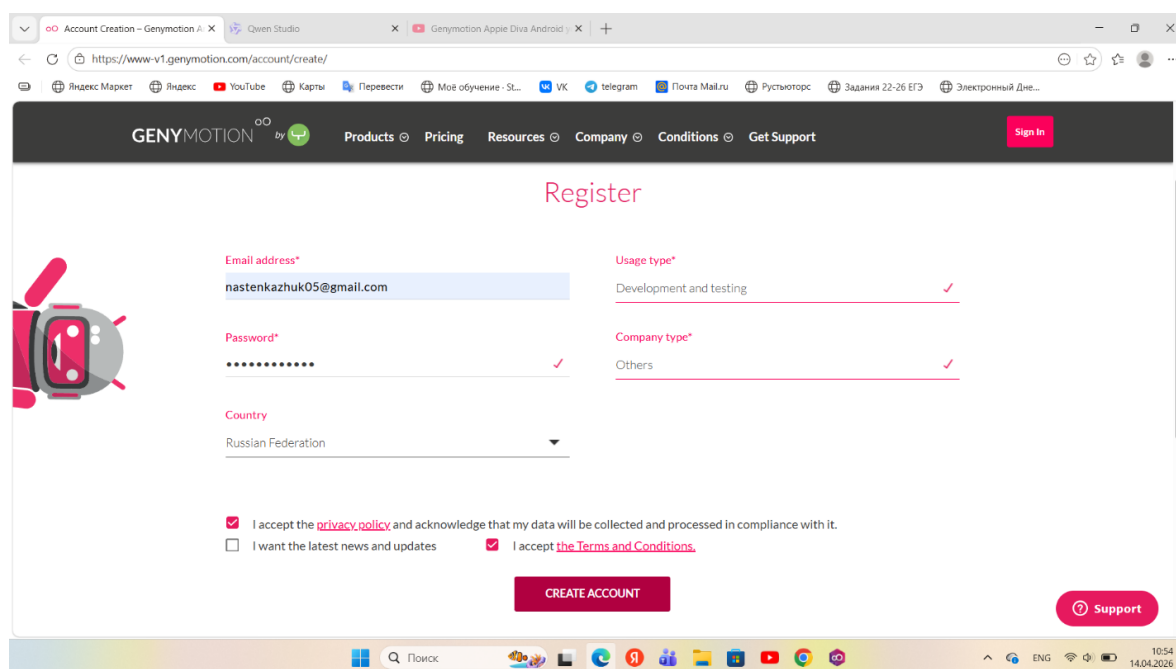


Рисунок 3 – Заполненная форма регистрации

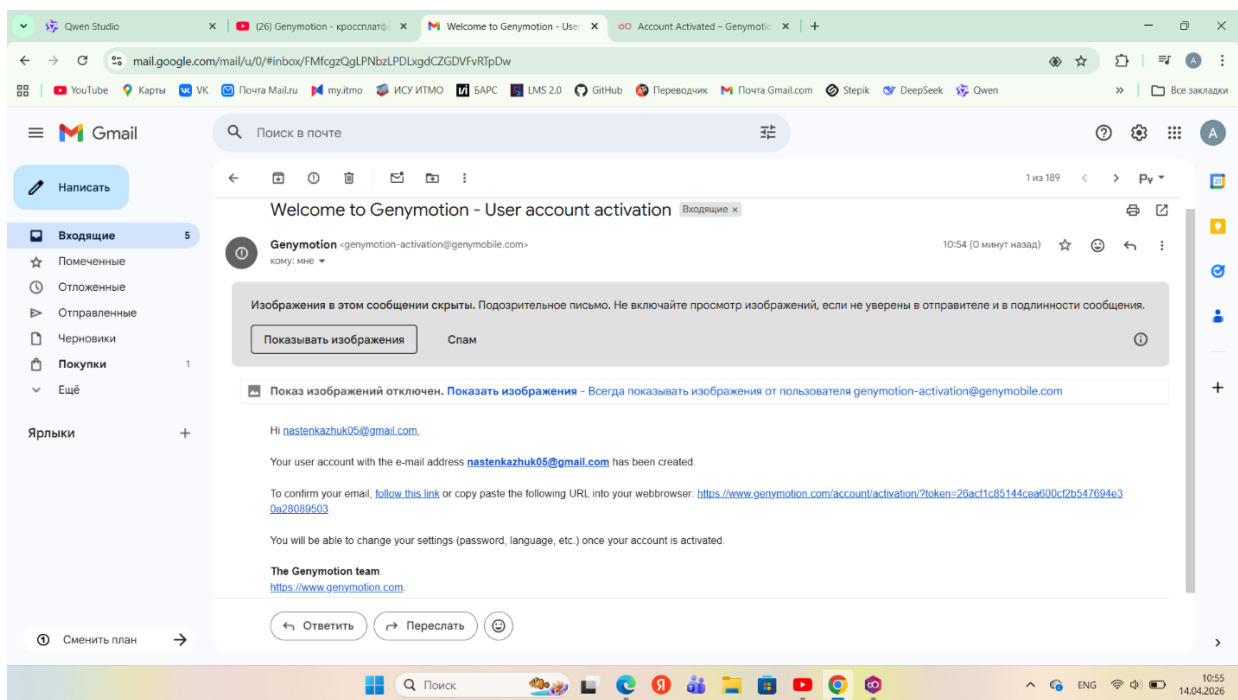


Рисунок 4 – Письмо с ссылкой для подтверждения

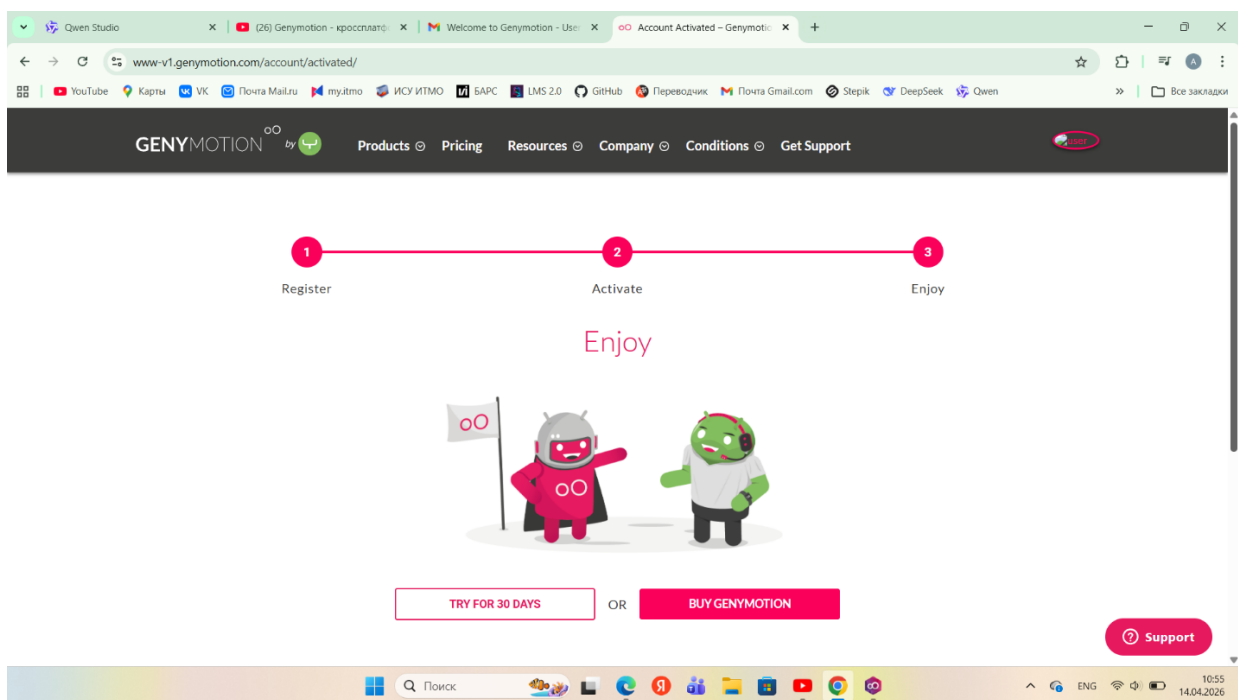


Рисунок 5 – Успешная регистрация

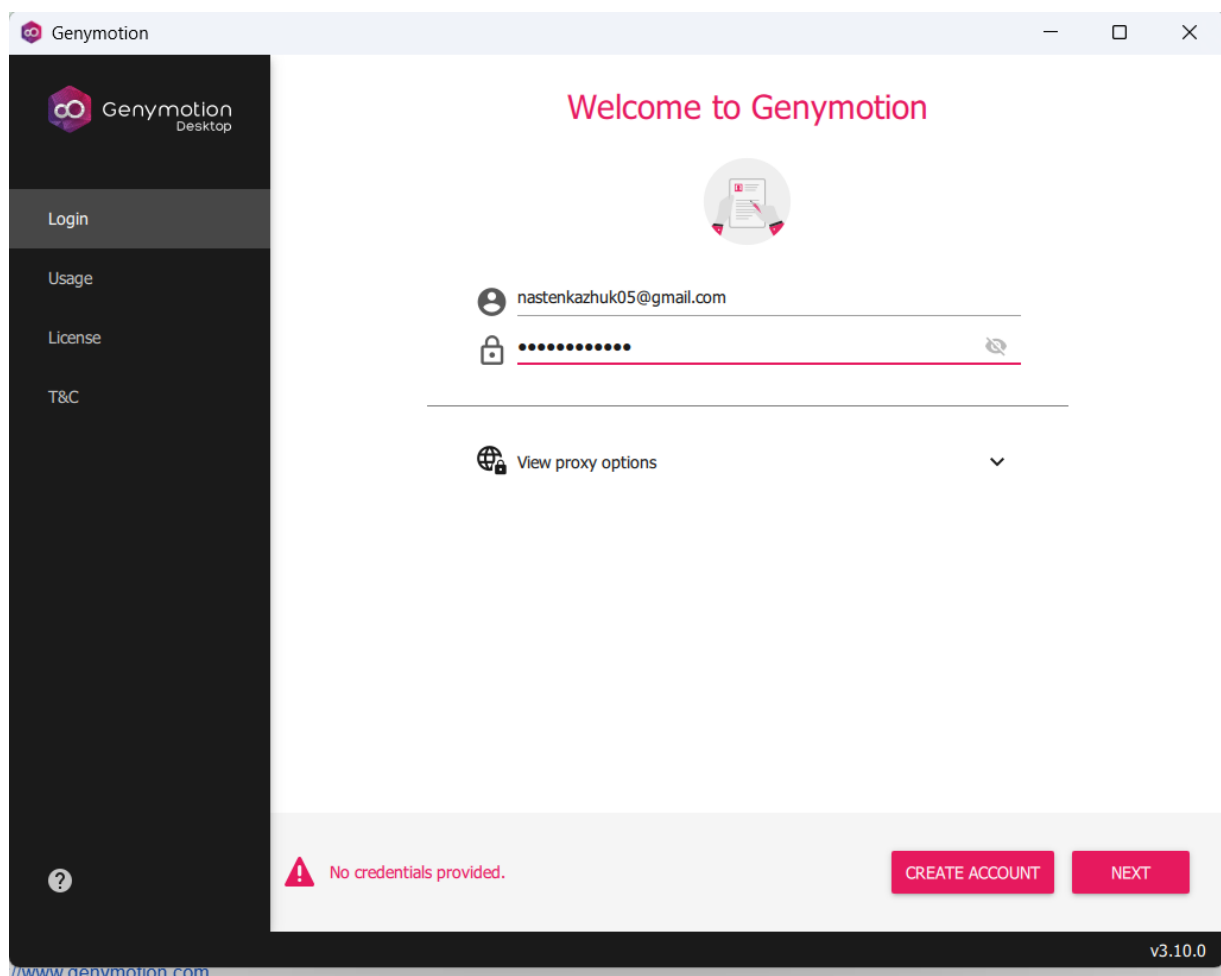


Рисунок 6 – Вход в Genymotion

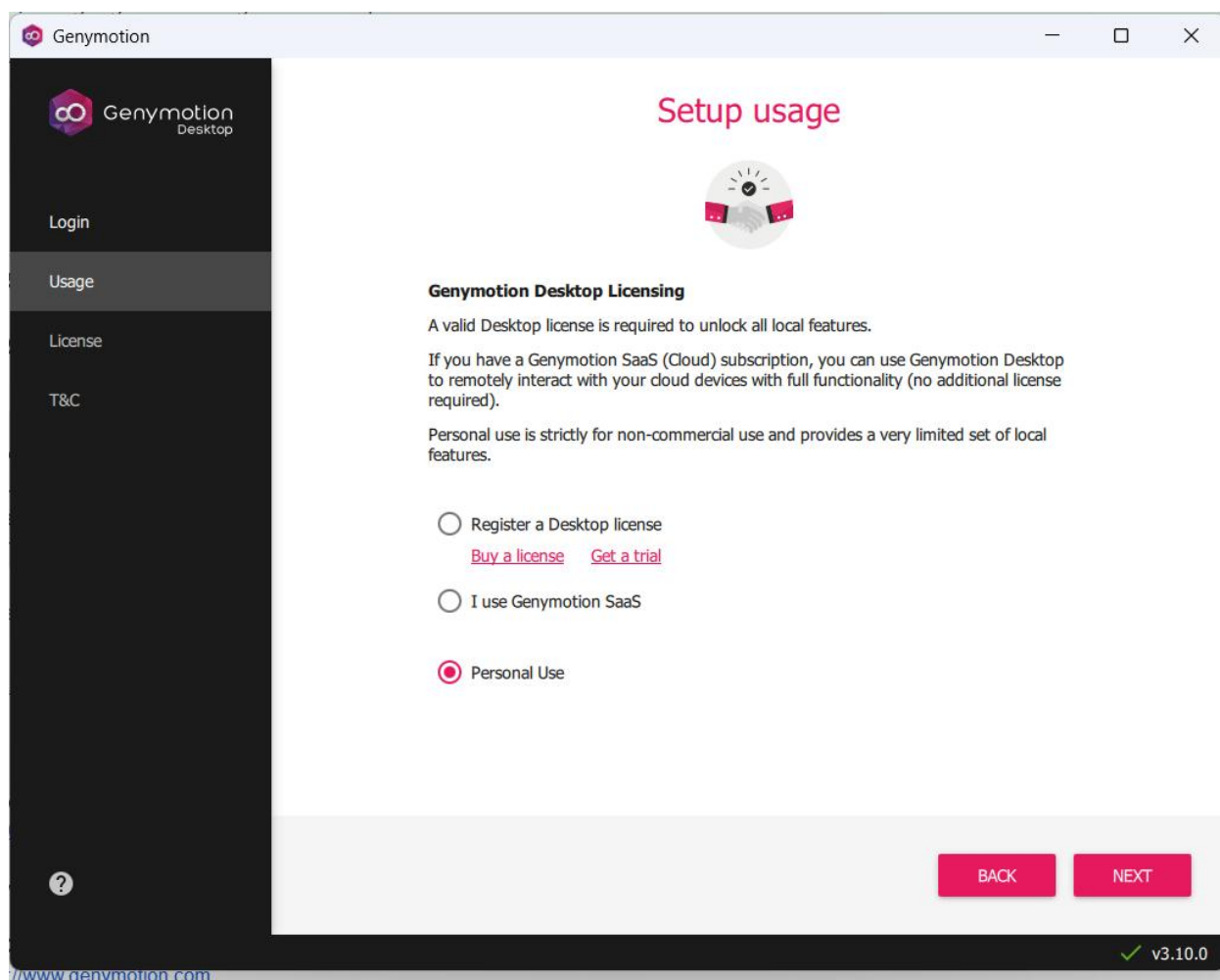


Рисунок 7 –Персональное использование приложения

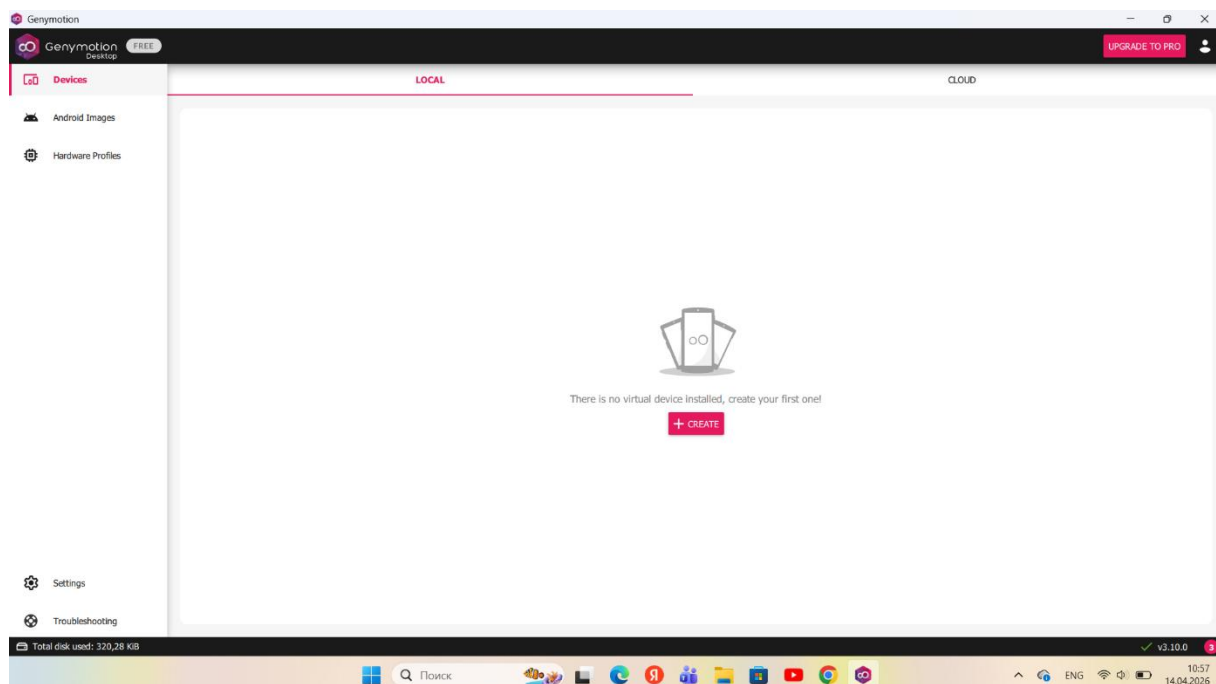


Рисунок 8 – Приложение Genymotion

1.3 Appie

На рисунках 9 – 11 представлена настройка нового пути adb с новым Appie.

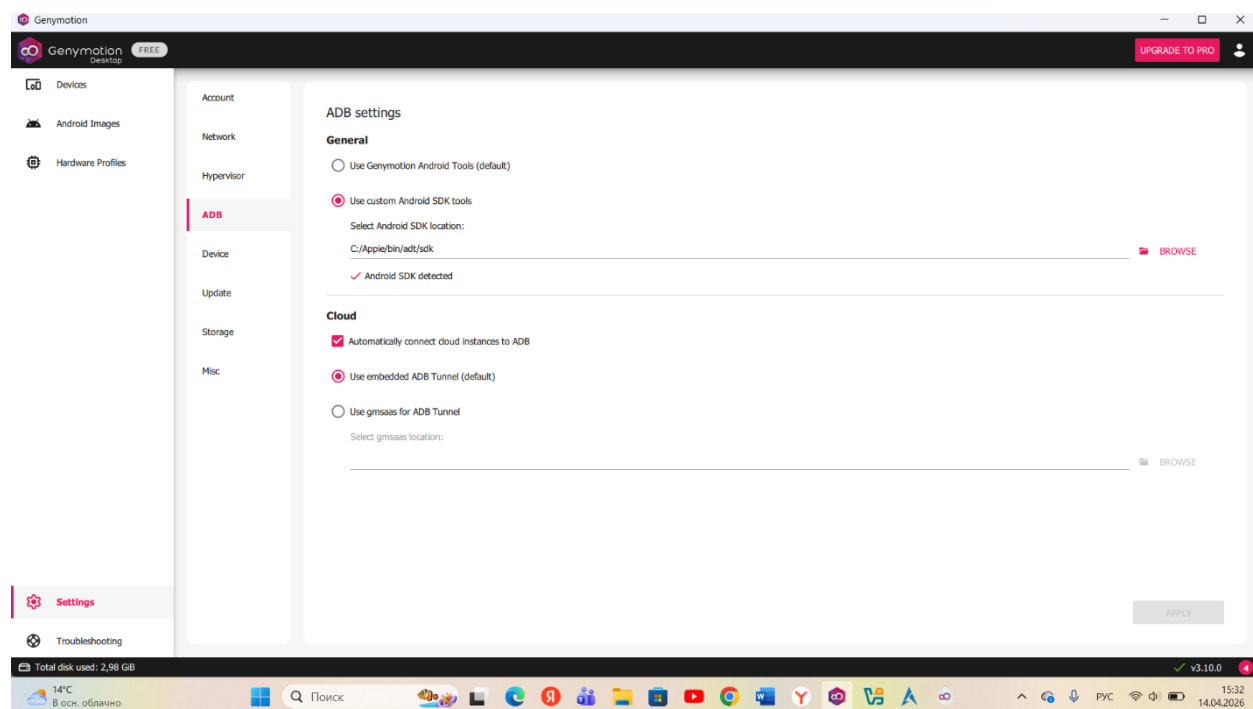


Рисунок 9 – Установка пути adb, по которому находится Appie

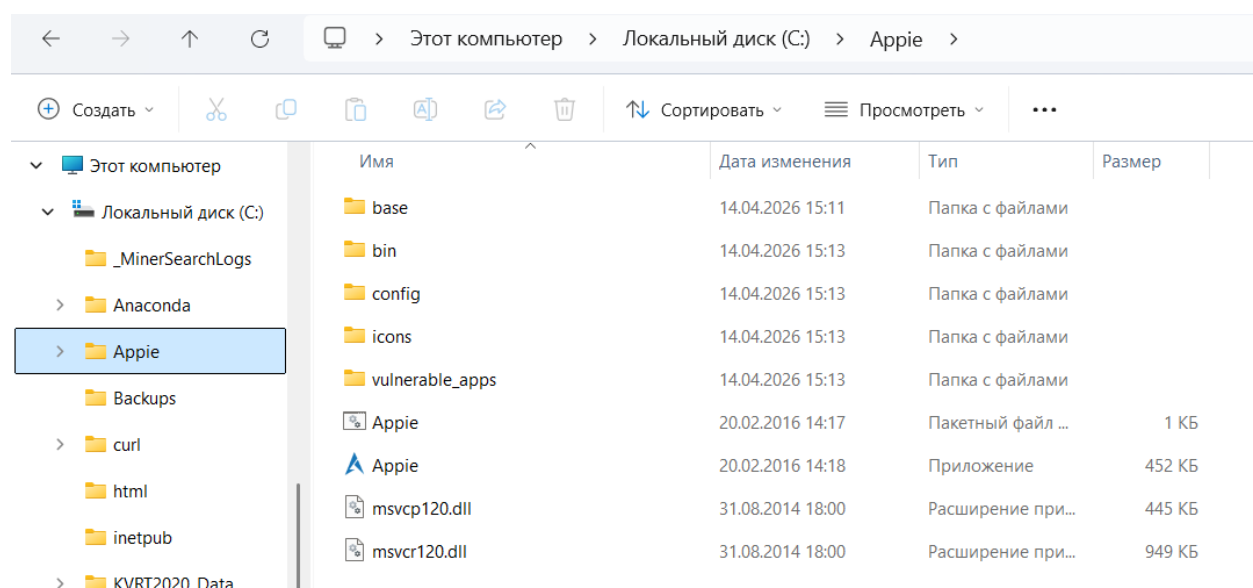


Рисунок 10 – Содержание скаченного Appie

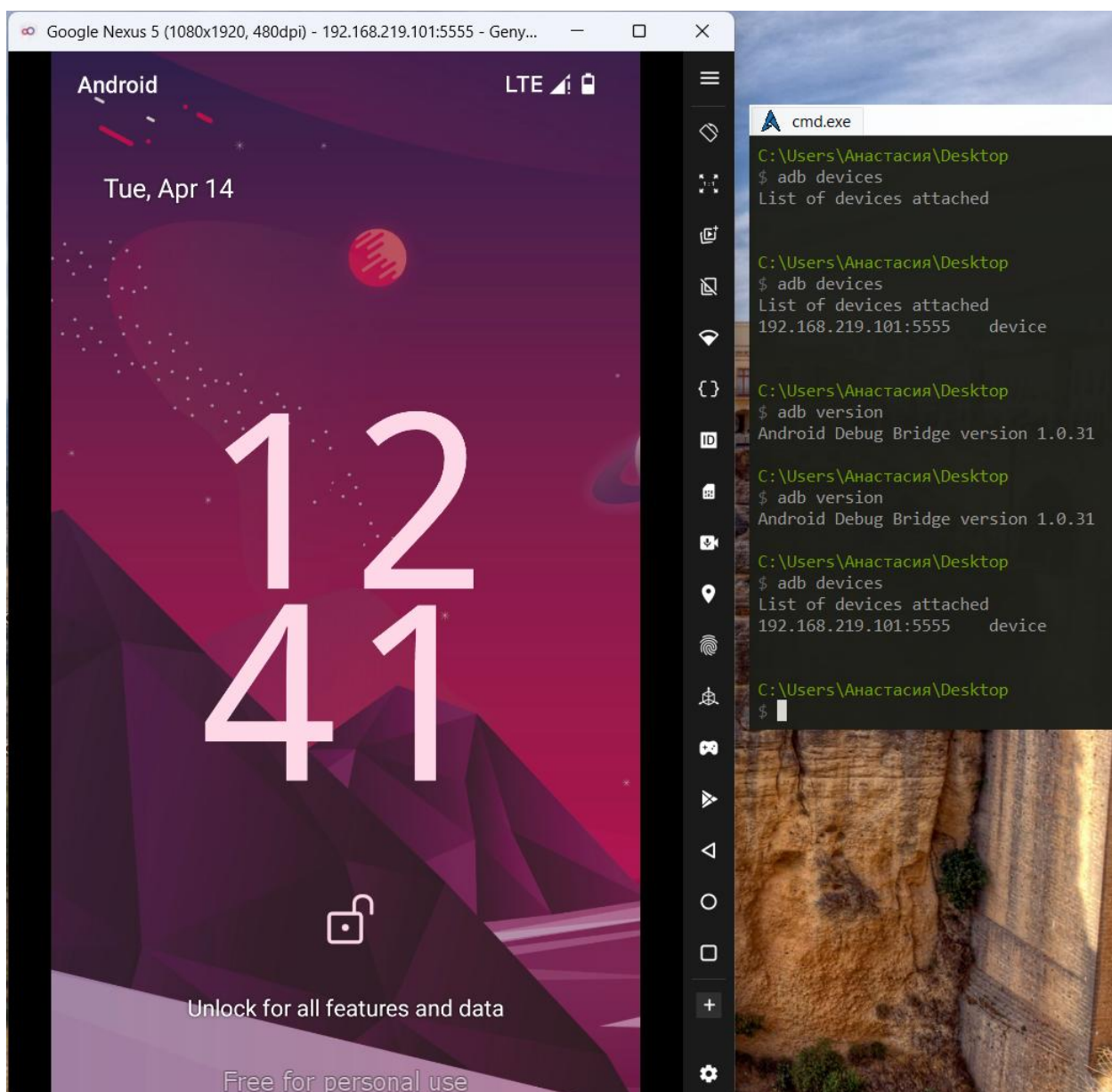


Рисунок 11 – Проверка подключения Appie к Android-дивайсу

1.4 Diva

Начнем с того, что пришлось скачать сначала java, чтобы подписать арк, так как на первой версии дивайса именно по этой причине не получалось установить приложение. Для подписи был скачан с помощью Uber APK Signer. Процесс и результат представлены на рисунках 12 и 13.

```
C:\Users\Анастасия\Desktop  
$ adb install "C:\Users\Анастасия\Downloads\diva-beta.apk"  
2896 KB/s (1475989 bytes in 0.497s)  
Failure [INSTALL_PARSE_FAILED_NO_CERTIFICATES: Failed to collect certificates from /data/app/vmdl173801995.tmp/base.apk: Attempt to get length of null array]
```

Рисунок 12 – Ошибка: APK не подписан

```

C:\Users\Анастасия>java -version
java version "1.8.0_481"
Java(TM) SE Runtime Environment (build 1.8.0_481-b10)
Java HotSpot(TM) 64-Bit Server VM (build 25.481-b10, mixed mode)

C:\Users\Анастасия>cd C:\Users\Анастасия\Downloads

C:\Users\Анастасия\Downloads>java -jar uber-apk-signer-1.3.0.jar --apks diva-beta.apk
source:
  C:\Users\*****\Downloads
binary-lib/windows-33_0_2/libwinpthread-1.dll
C:\Users\08DE~1\AppData\Local\Temp\uapksigner-5486839443150208005
zipalign location: BUILT_IN
  C:\Users\08DE~1\AppData\Local\Temp\uapksigner-5486839443150208005\win-zipalign_33_0_2.exe1526579078648768810.tmp
keystore:
  [0] 161a0018 C:\Users\*****\AppData\Local\Temp\temp_2128312145666566860_debug.keystore (DEBUG_EMBEDDED)

01. diva-beta.apk

SIGN
file: C:\Users\*****\Downloads\diva-beta.apk (1.41 MiB)
checksum: da829be17746f2c76996e10dda957218c5d7a9a3c8a5a49b3bd414f5e0492dca (sha256)
- zipalign success
- sign success

VERIFY
file: C:\Users\*****\Downloads\diva-beta-aligned-debugSigned.apk (1.44 MiB)
checksum: 66bd13988f80d8b068896c56acdb3bd10eef6707a21426e1b6255fe2958d35b7 (sha256)
- zipalign verified
- signature verified [v1, v2, v3]
  Subject: CN=Android Debug, OU=Android, O=US, L=US, ST=US, C=US
  SHA256: 1e08a903aef9c3a721510b64ec764d01d3d094eb954161b62544ea8f187b5953 / SHA256withRSA
  Expires: Thu Mar 10 23:10:05 MSK 2044

[Tue Apr 14 16:15:24 MSK 2026][v1.3.0]
Successfully processed 1 APKs and 0 errors in 1.33 seconds.

```

Рисунок 13 – Процесс подписания APK

После удачной подписи появилась новая ошибка. Приложение Diva требовало Android SDK версии 23, а эмулятор (Google Nexus 5) требовал минимум SDK 24 (Android 7.0+) (рисунок 14). Из-за чего пришлось сделать новый эмулятор Google Nexus 5_1 с настройками, показанными на рисунках 15 и 16.

```

C:\Users\Анастасия\Downloads
$ adb install "C:\Users\Анастасия\Downloads\diva-beta-aligned-debugSigned.apk"
2900 KB/s (1508007 bytes in 0.507s)
Failure [INSTALL_FAILED_DEPRECATED_SDK_VERSION: App package must target at least SDK version 24, but found 23]

```

Рисунок 14 – Ошибка несовместимости версий Android SDK

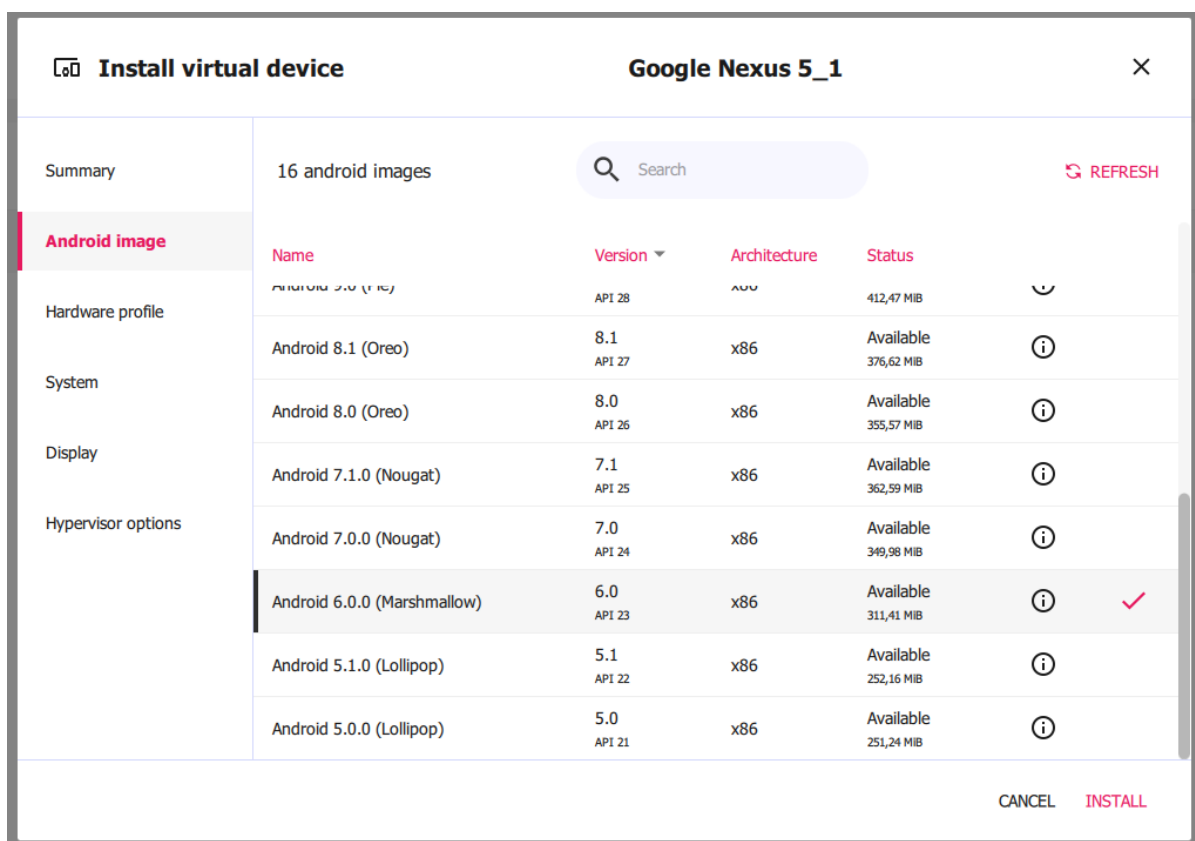


Рисунок 15 – Создание нового дивайса (1)

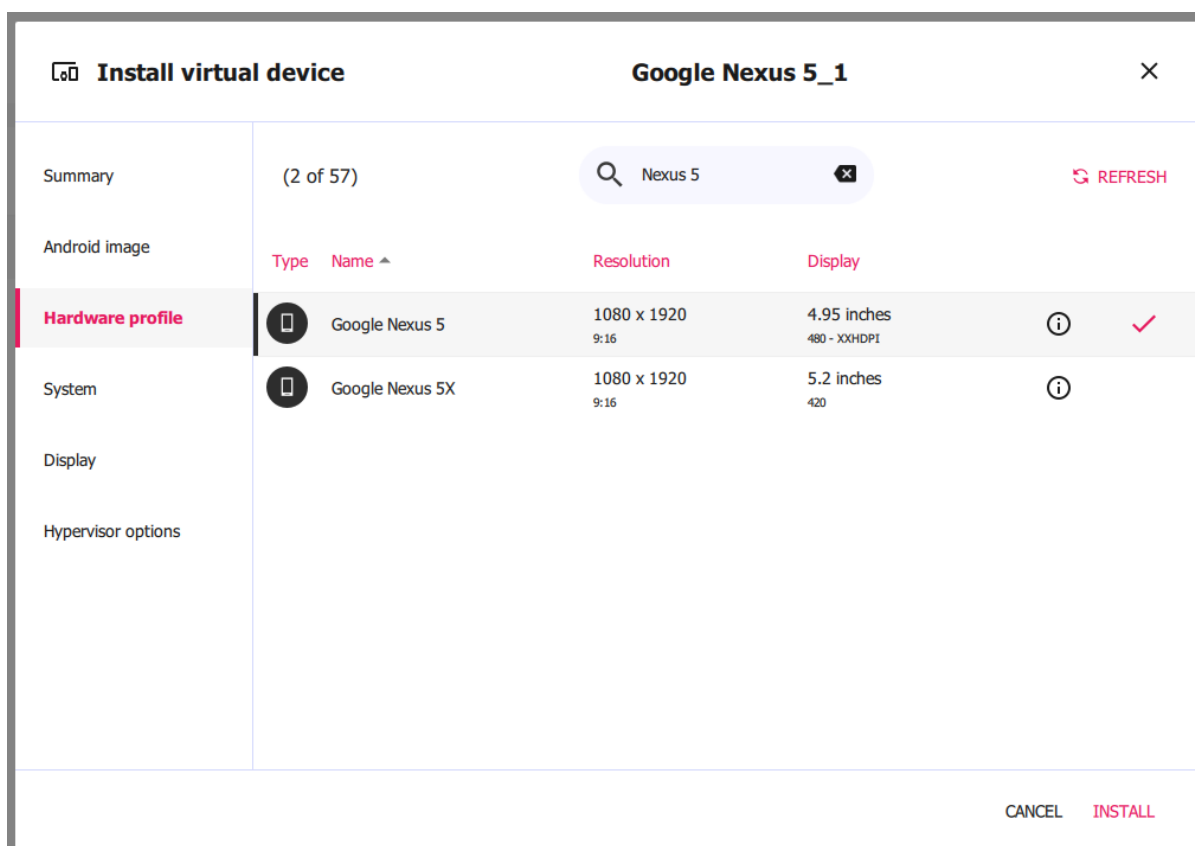


Рисунок 16 – Создание нового дивайса (2)

Только после этого все получилось. Результат представлен на рисунках 17 и 18.

```
C:\Users\Анастасия\Downloads
$ adb devices
List of devices attached
192.168.219.102:5555    device

C:\Users\Анастасия\Downloads
$ adb install "C:\Users\Анастасия\Downloads\diva-beta-aligned-debugSigned.apk"
3277 KB/s (1508007 bytes in 0.449s)
    pkg: /data/local/tmp/diva-beta-aligned-debugSigned.apk
Success
```

Рисунок 17 – Успешная установка приложения Diva на виртуальный дивайс

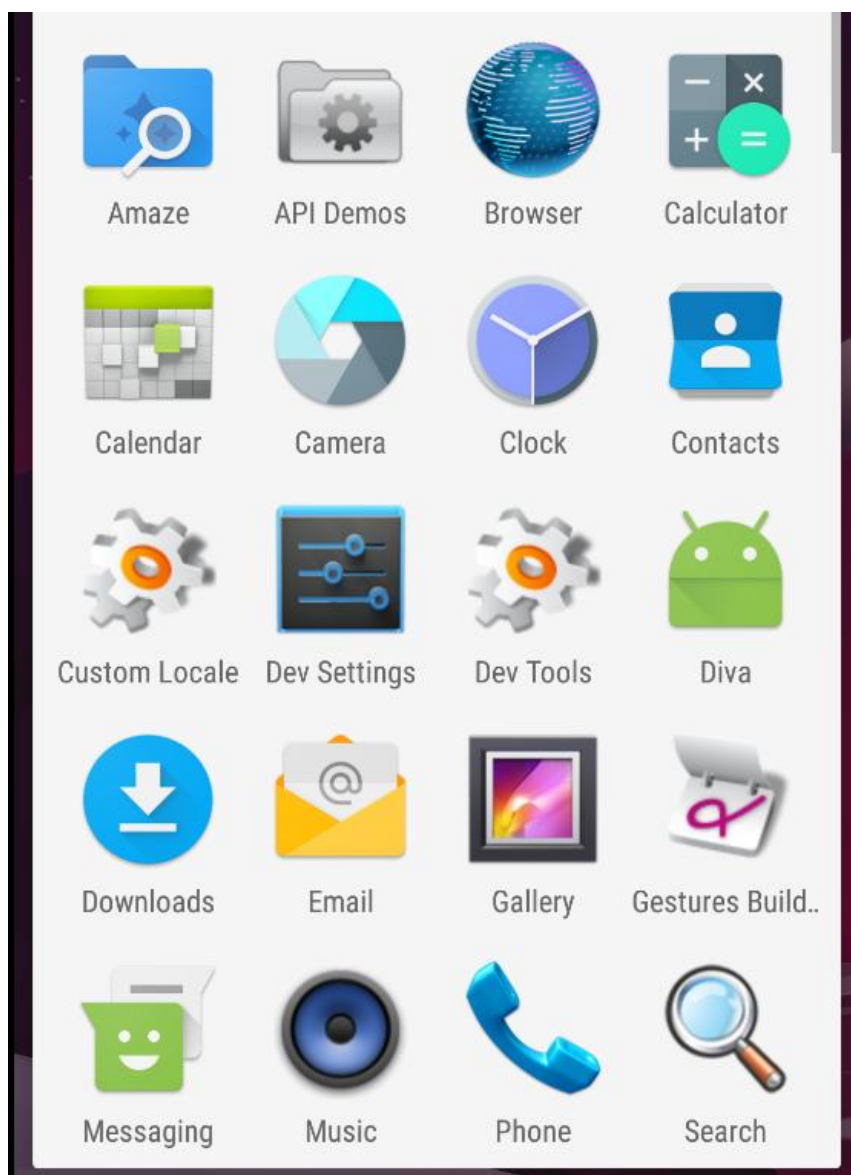


Рисунок 18 – Наличие приложения Diva на дивайсе

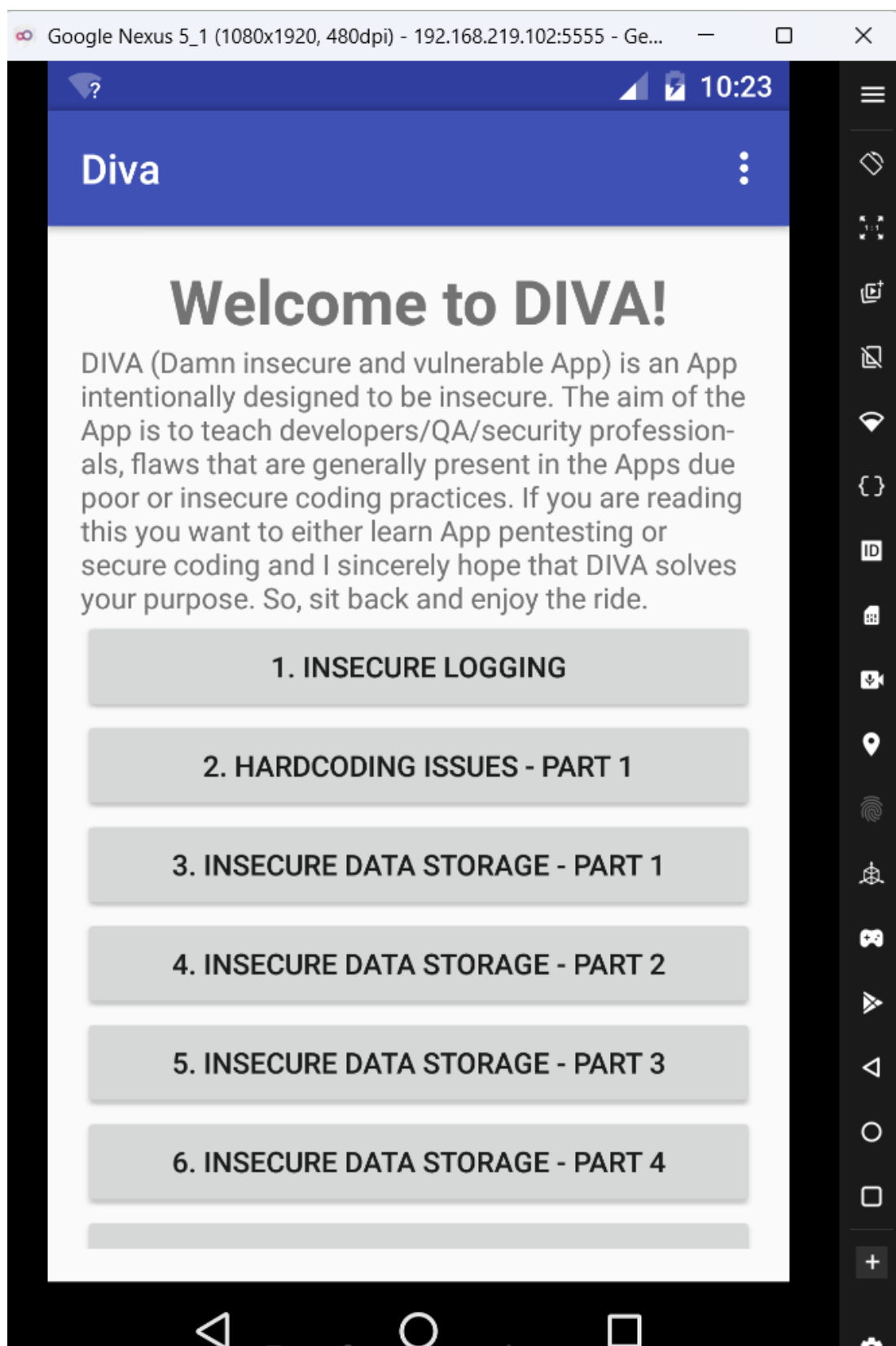


Рисунок 19 – Кейсы в Diva Android (1)

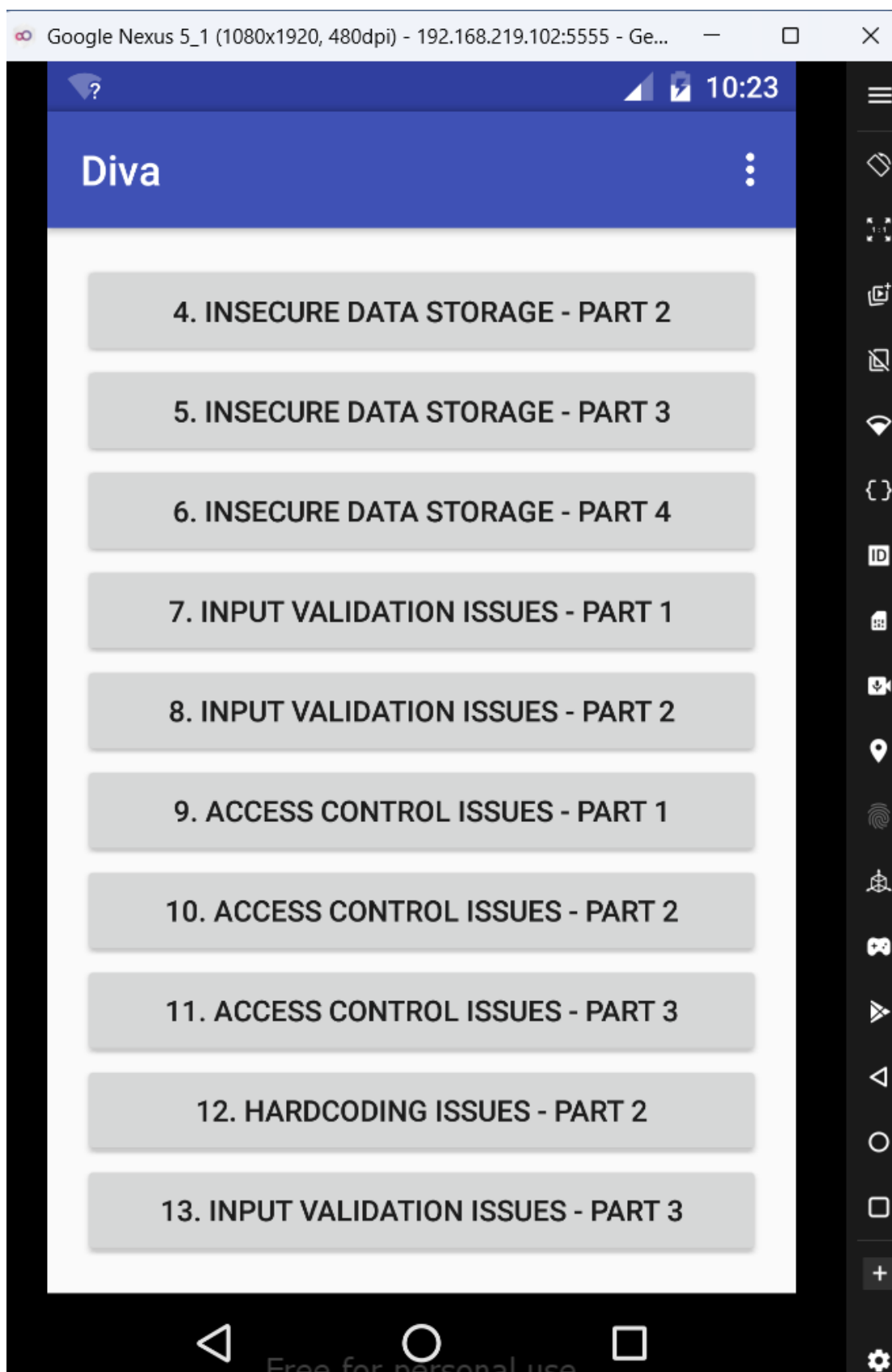


Рисунок 20 – Кейсы в Diva Android (2)

2.1 Insecure Logging

На рисунке 21 представлено задание.

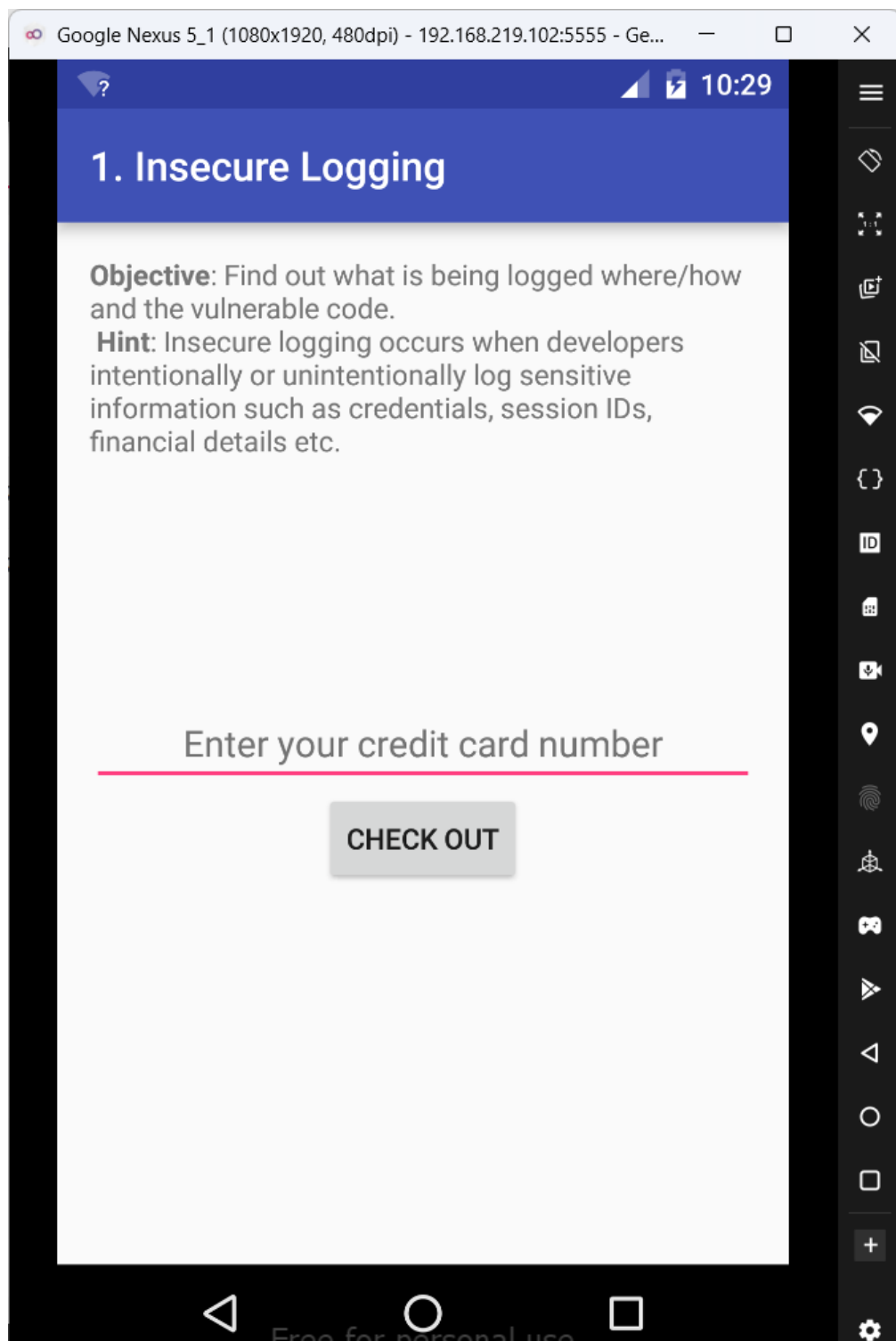


Рисунок 21 – Содержание кейса Insecure Logging

Задача: найти, что, где и как регистрируется в журнале, а также найти уязвимый код.

Подсказка: разработчики иногда записывают в логи чувствительные данные: пароли, сессии, финансовые данные и т.д.

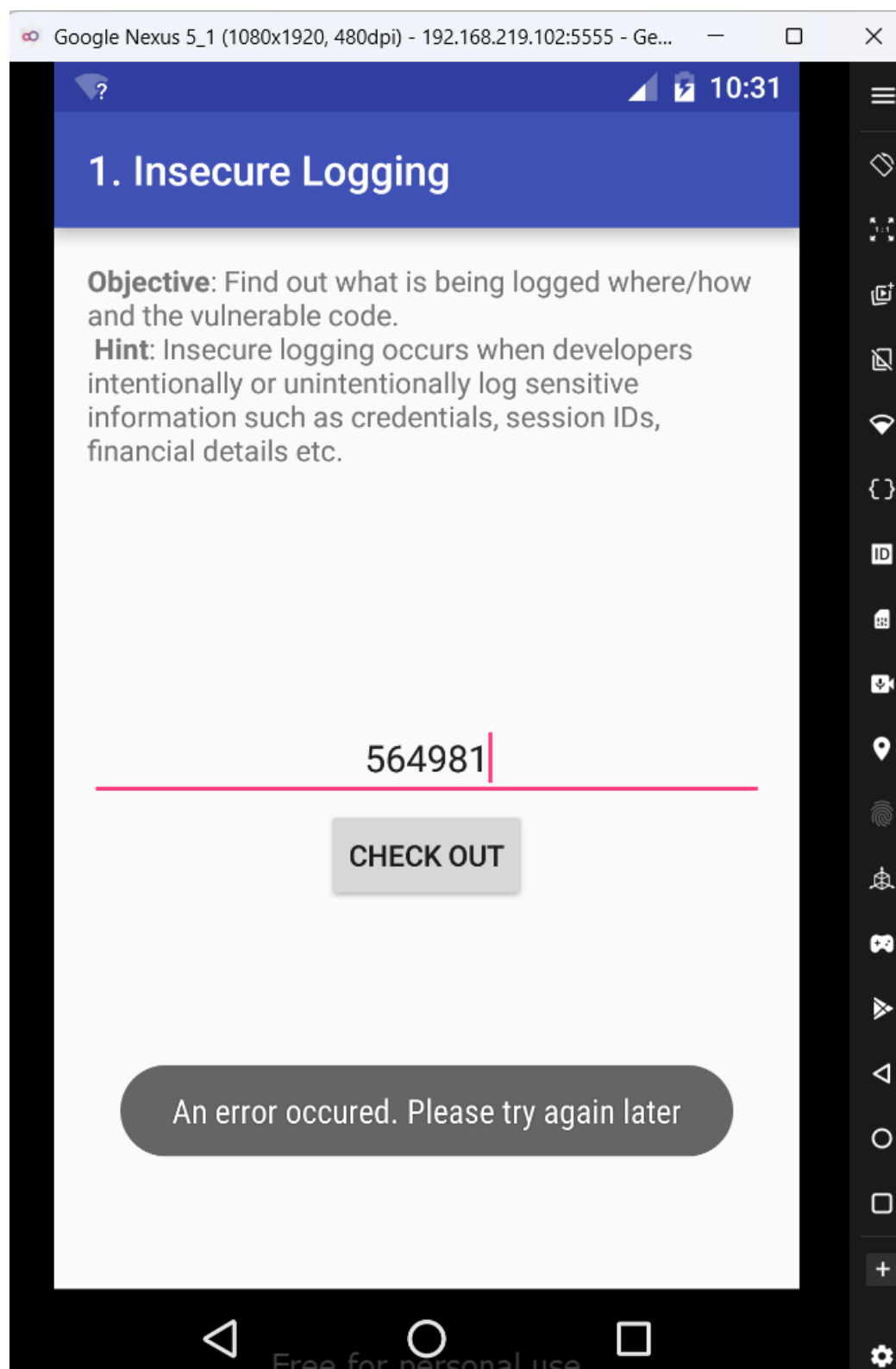


Рисунок 22 – Попытка введения информации в поле для записи

```

C:\Users\Анастасия\Downloads
$ adb logcat | grep diva
04-14 09:27:32.227 1585 1596 D DefContainer: Copying /data/local/tmp/diva-beta-aligned-debugSigned.apk to base.apk
04-14 10:23:21.618 624 1144 I ActivityManager: START u0 {act=android.intent.action.MAIN cat=[android.intent.category.LAUNCHER] flg=0x10200000 cmp=jakhar.aseem.diva/.MainActivity (has extras)} from uid 10008 on display 0
04-14 10:23:21.661 624 641 I ActivityManager: Start proc 4239:jakhar.aseem.diva/u0a60 for activity jakhar.aseem.diva/.MainActivity
04-14 10:23:22.285 624 650 I ActivityManager: Displayed jakhar.aseem.diva/.MainActivity: +635ms
04-14 10:29:50.036 624 788 I ActivityManager: START u0 {cmp=jakhar.aseem.diva/.LogActivity} from uid 10060 on display 0
04-14 10:29:50.185 624 650 I ActivityManager: Displayed jakhar.aseem.diva/.LogActivity: +143ms
04-14 10:31:23.096 4239 4239 E diva-log: Error while processing transaction with credit card: 564981
04-14 10:34:16.458 4239 4239 E diva-log: Error while processing transaction with credit card: 564981

```

Рисунок 23 – Логи приложения Diva

Уязвимый код: разработчик намеренно выводит данные карты в лог. Посмотрим код приложения, чтобы выяснить в чем дело. Для этого пришлось отдельно установить приложение для анализа кода JADX.

Так как изначально мы не знаем, где находится код данного кейса, нужно обратиться к файлу AndroidManifest.xml и ищем действие, связанное с логированием (рисунок 24).

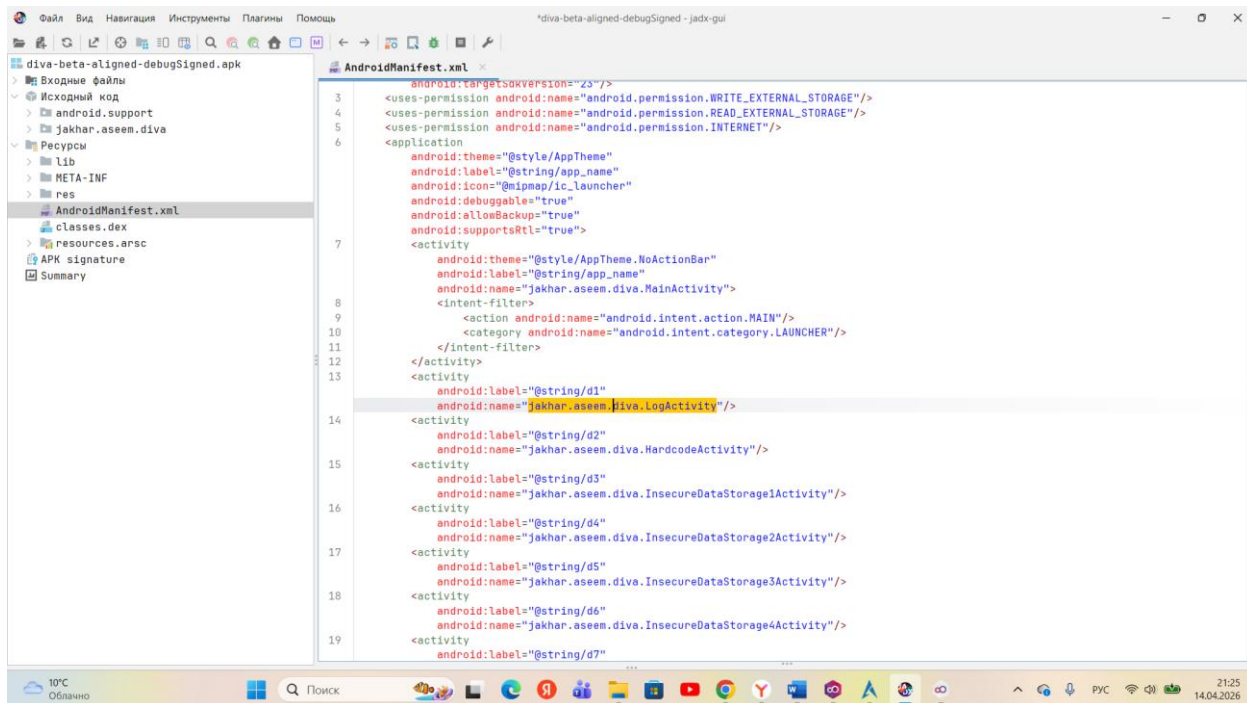


Рисунок 24 – Действие, связанное с логированием, в файле AndroidManifest.xml

Переходим к соответствующему файлу и анализируем уже его.

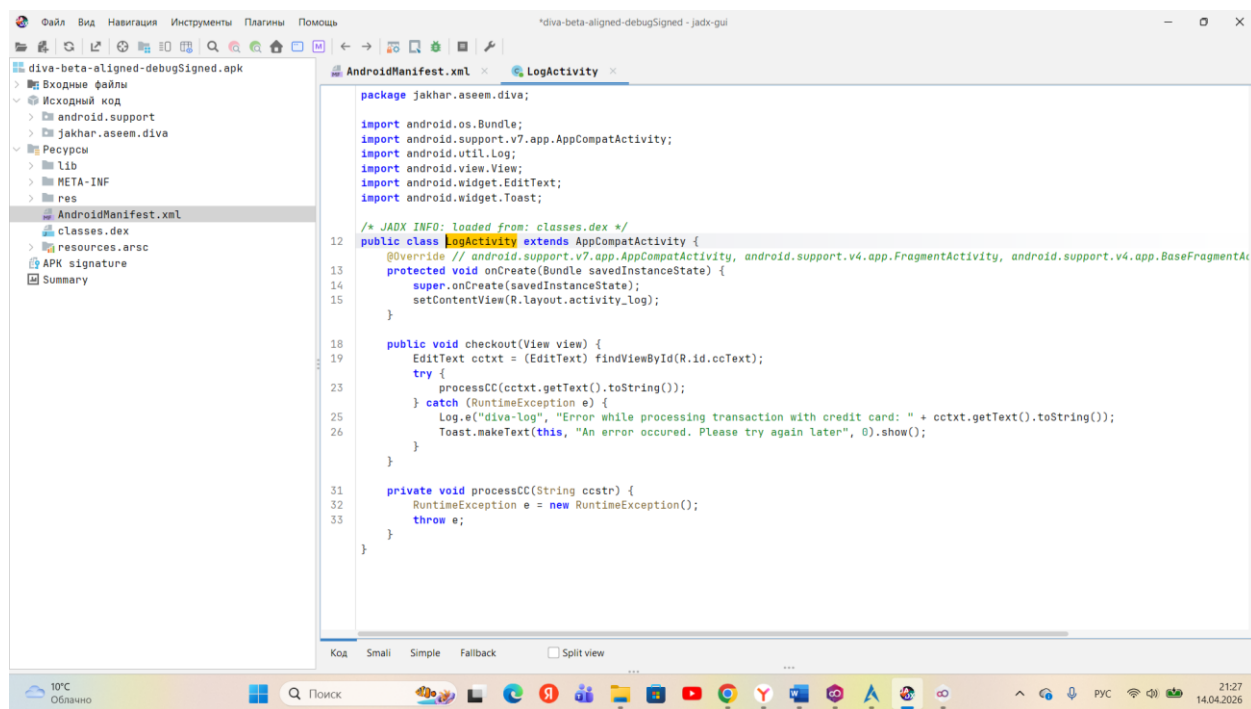


Рисунок 25 – Исходный код для логов

В этом и заключается основная уязвимость: все конфиденциальные данные попадают в логи, которые видят все.

2.2 Hardcoding issue part 1

На рисунке 26 представлено задание.

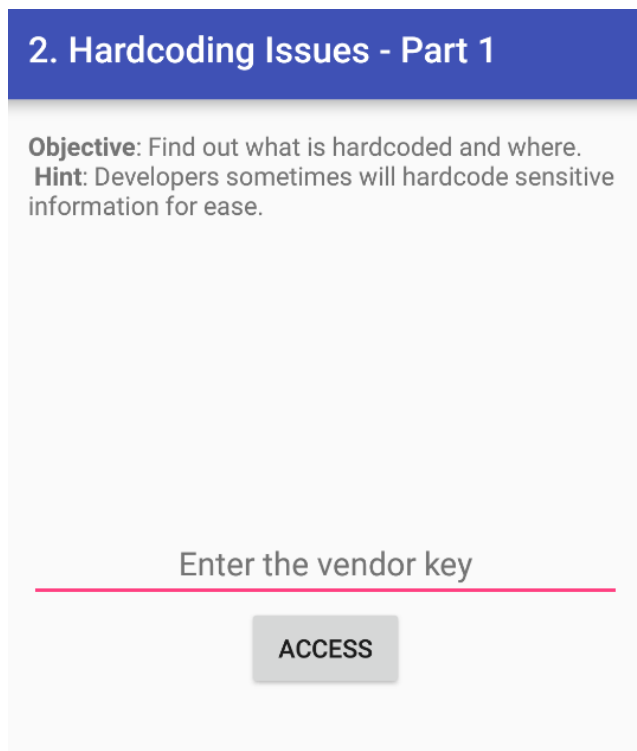


Рисунок 26 – Условие Hardcoding issue part 1

Цель: найти, что и где захардкожено.

Подсказка: разработчики иногда жестко кодируют конфиденциальную информацию для удобства.

На рисунке 27 представлен результат ввода произвольного лицензионного ключа.

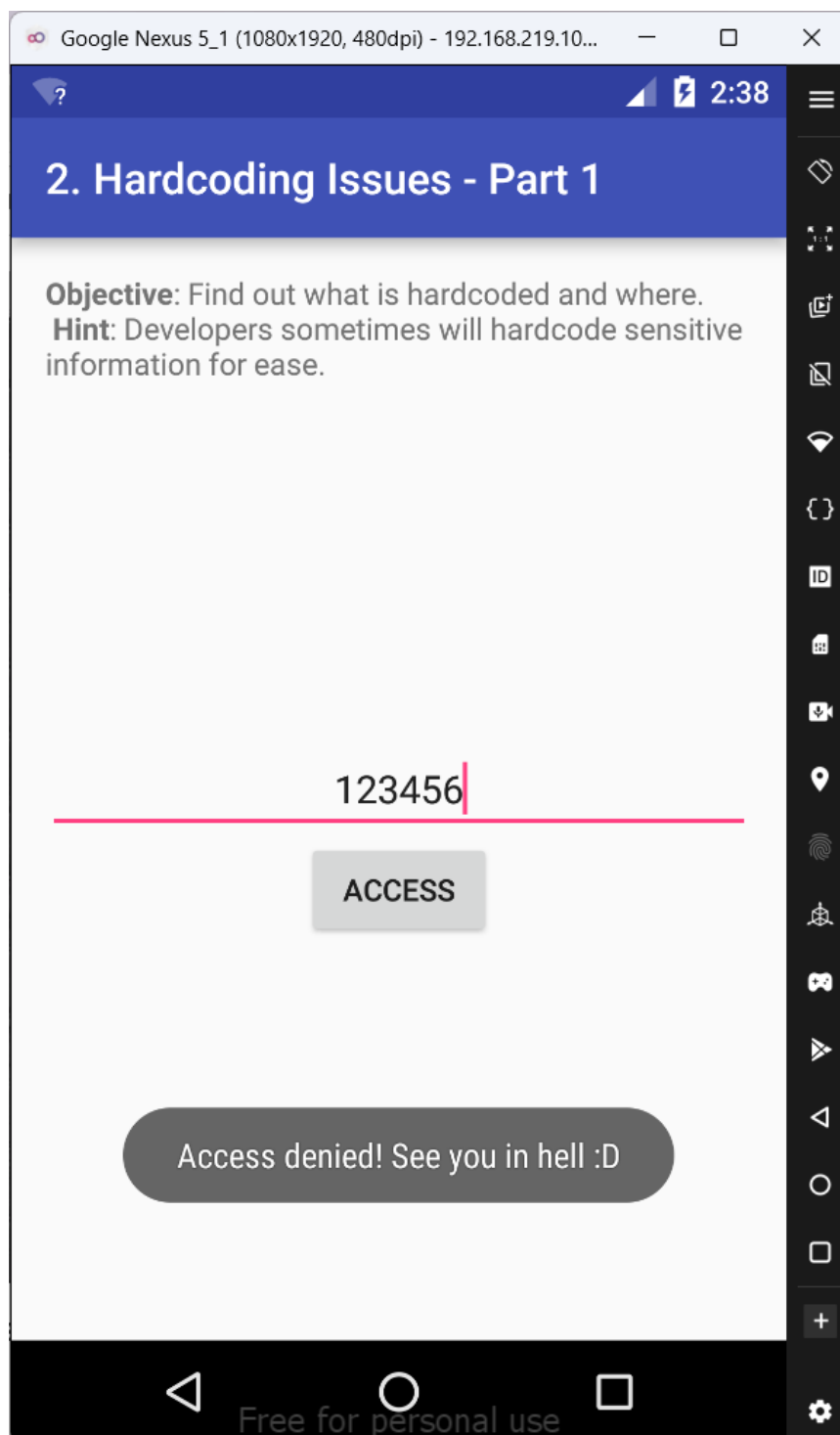


Рисунок 27 – Результат ввода неверного лицензионного ключа

Снова обращаемся к исходному коду приложения. Изучаем манифест (рисунок 28). Находим действие по ключевым словам и переходим к исходному коду (рисунок 29). Изучив его, можно заметить, что там в открытом виде лежит лицензионный код, который и нужно ввести в поле (рисунок 30).

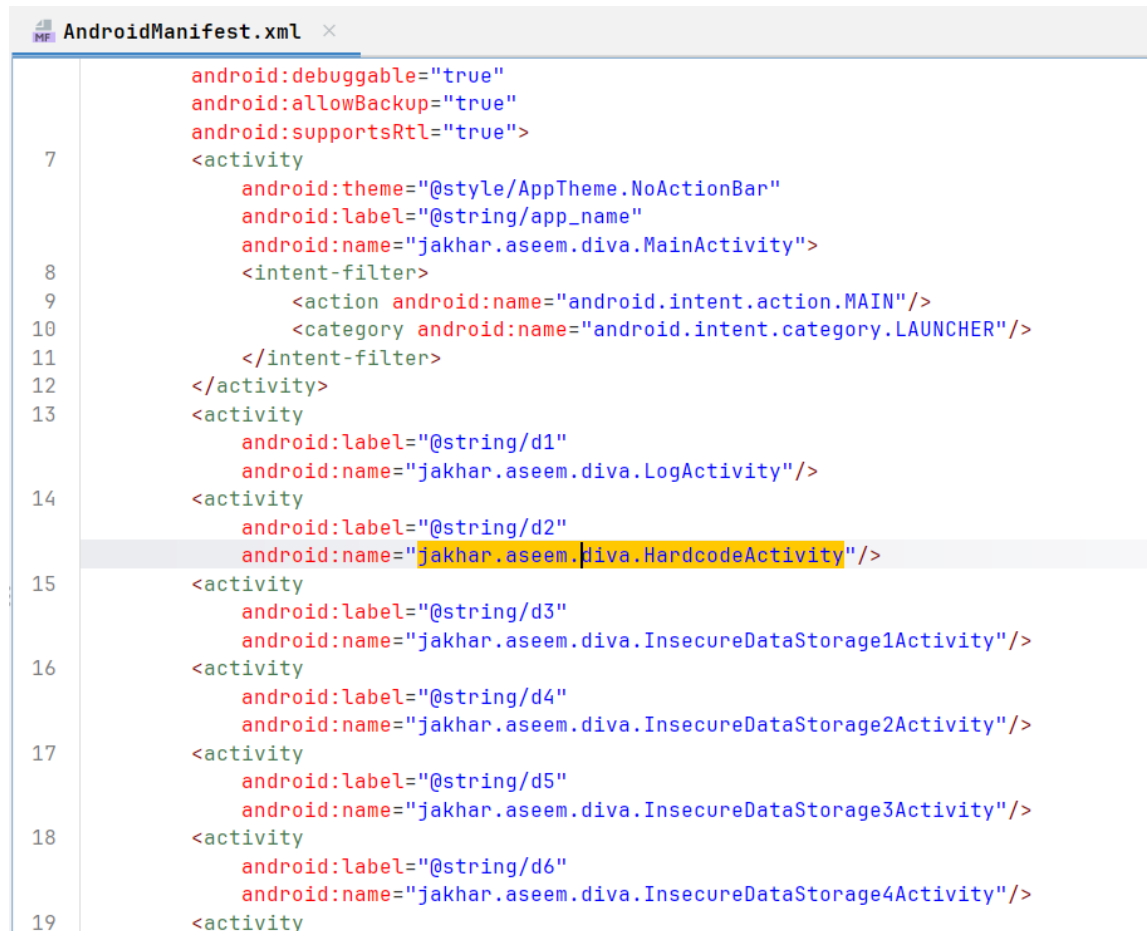


Рисунок 28 – Анализ манифеста

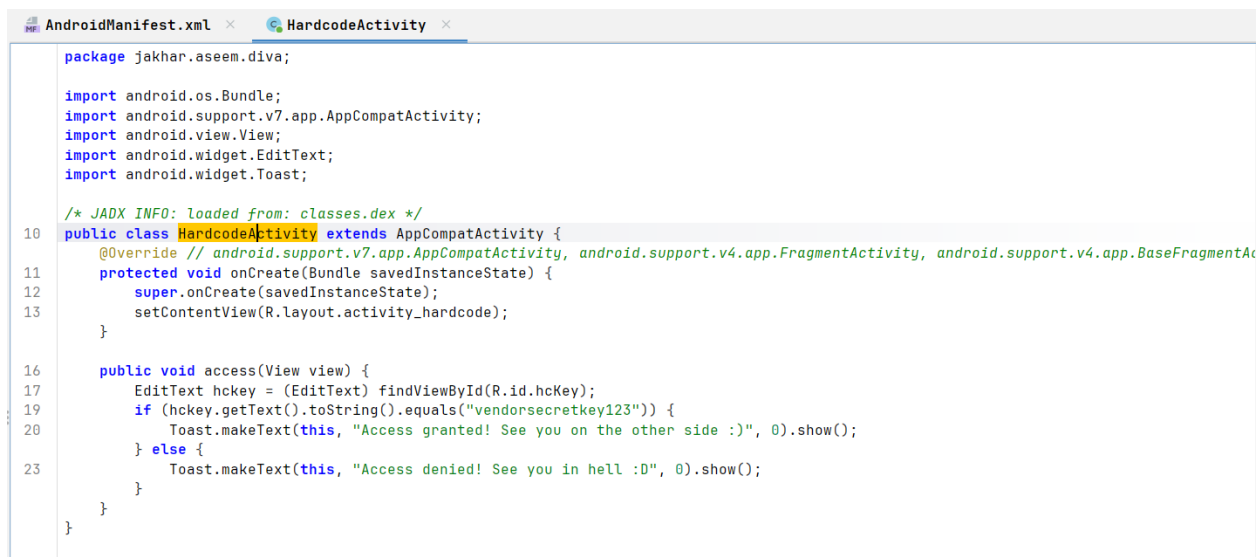


Рисунок 29 – Исходный код данного кейса

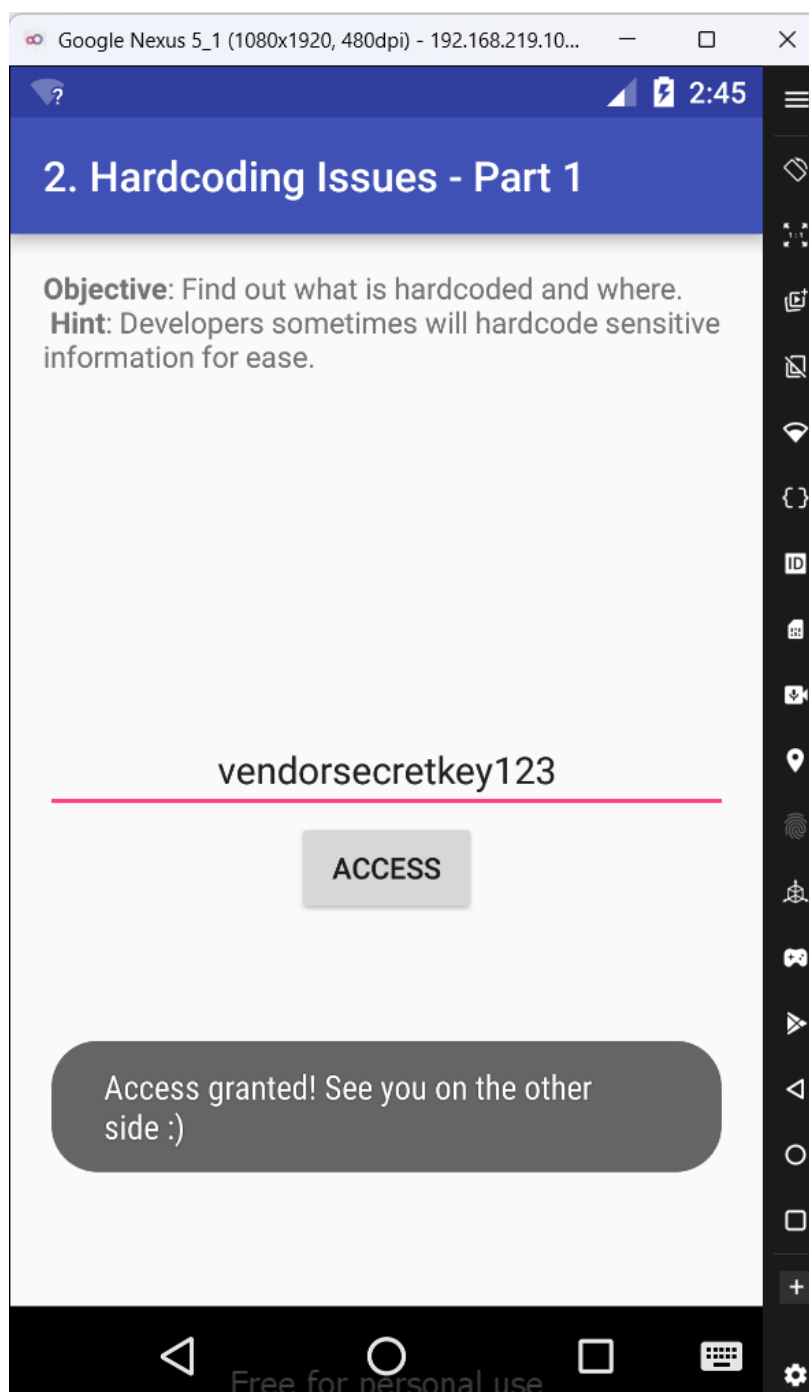


Рисунок 30 – Успешно введенный ключ

Уязвимость тут заключается в том, что в исходном тексте находится в открытом виде секретная информация. В целом, любой человек может узнать ее, если откроет исходный код приложения с помощью JADX.

2.3 Insecure Data Storage Part 1

На рисунке 31 представлено задание.

3. Insecure Data Storage - Part 1

Objective: Find out where/how the credentials are being stored and the vulnerable code.

Hint: Insecure data storage is the result of storing confidential information insecurely on the system i.e. poor encryption, plain text, access control issues etc.



The screenshot shows a web form with two input fields. The first field is labeled 'Enter 3rd party service user name' and the second field is labeled 'Enter 3rd party service passwo'. Both fields are underlined. Below the second field is a button labeled 'SAVE'.

Рисунок 31 – Задание третьего кейса

Цель: найти, где и как хранятся учетные данные, и найти уязвимый код.

Подсказка: небезопасное хранение данных является результатом хранения конфиденциальной информации на системе небезопасным образом, т.е. слабое шифрование, открытый текст (plain text), проблемы с контролем доступа и т.д.

Сначала введем какие-нибудь данные и сохраним их (этот процесс представлен на рисунке 32).

3. Insecure Data Storage - Part 1

Objective: Find out where/how the credentials are being stored and the vulnerable code.

Hint: Insecure data storage is the result of storing confidential information insecurely on the system i.e. poor encryption, plain text, access control issues etc.



The screenshot shows a web form with a blue header bar containing the text "3. Insecure Data Storage - Part 1". Below the header, there is a light gray box containing the following elements: an "Objective" section stating "Find out where/how the credentials are being stored and the vulnerable code.", a "Hint" section stating "Insecure data storage is the result of storing confidential information insecurely on the system i.e. poor encryption, plain text, access control issues etc.", a text input field containing the text "abcde", a password input field represented by five dots, a "SAVE" button, and a dark gray rounded rectangle containing the text "3rd party credentials saved successfully!".

Рисунок 32 – Введение и сохранение данных

Снова обращаемся к исходному коду, а именно к манифесту (рисунок 33). Находим третье действие, которое соответствует названию кейса. Переходим к его исходному коду (рисунок 34).

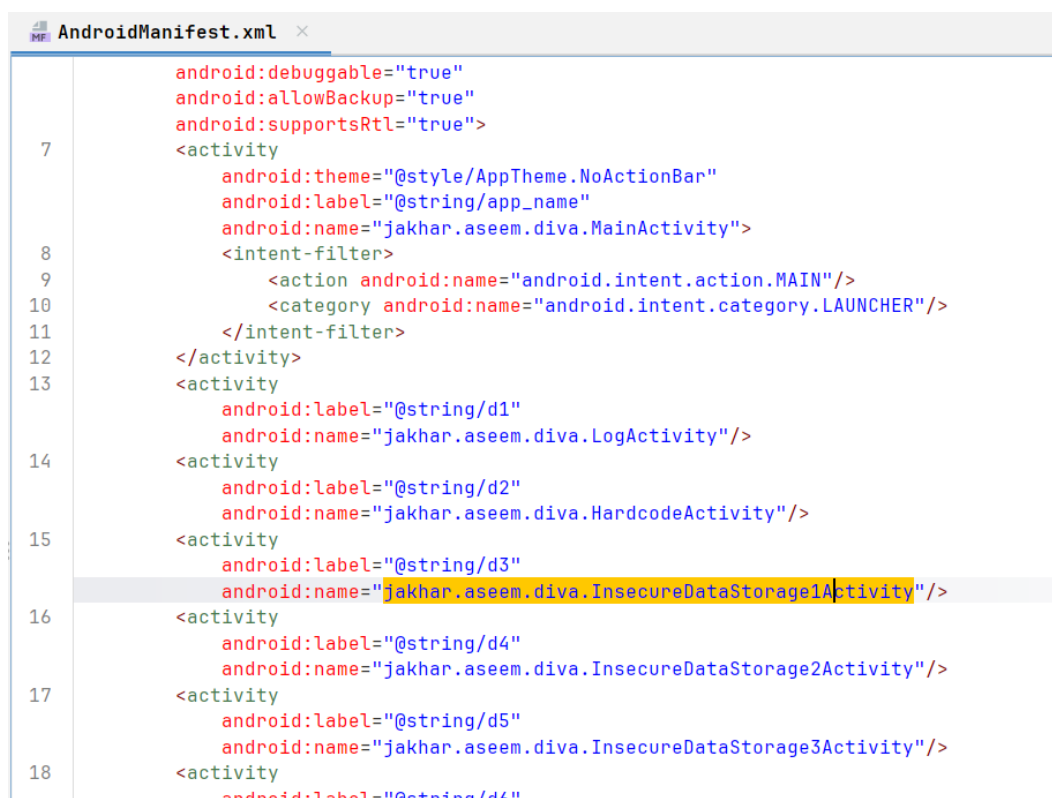


Рисунок 33 – Анализ манифеста



Рисунок 34 – Исходный код третьего кейса

Хранение конфиденциальной информации осуществляется в spedit. В Android существует 4 места, где можно хранить данные ввода и вывода: xml-файлы (Shared Preferences), базы данных, временные файлы (temp-файлы) и внешние хранилища. В нашем случае мы храним в xml-файле в виде ключ-значение. Данные будут храниться в общих настройках (рисунки 35 и 36).

```

C:\Users\Анастасия\Desktop
$ adb shell
root@vbox86p:/ # cd /data/data
cd /data/data
root@vbox86p:/data/data # cd jakhar.aseem.diva/
cd jakhar.aseem.diva/
/system/bin/sh: cd: /data/data/jakhar.aseem.diva: No such file or directory
2|root@vbox86p:/data/data # cd jakhar.aseem.diva/
cd jakhar.aseem.diva/
root@vbox86p:/data/data/jakhar.aseem.diva # ls -al
ls -al
drwxrwx--x u0_a60 u0_a60 2026-04-14 10:23 cache
drwxrwx--x u0_a60 u0_a60 2026-04-14 10:23 code_cache
drwxrwx--x u0_a60 u0_a60 2026-04-14 10:23 databases
lrwxrwxrwx root root 2026-04-14 14:21 lib -> /data/app/jakhar.aseem.diva-1/lib/x86
drwxrwx--x u0_a60 u0_a60 2026-04-14 14:55 shared_prefs
root@vbox86p:/data/data/jakhar.aseem.diva # cd shared_prefs/
cd shared_prefs/
root@vbox86p:/data/data/jakhar.aseem.diva/shared_prefs # |

```

Рисунок 35 – Просмотр общих настроек (1)

```

root@vbox86p:/data/data/jakhar.aseem.diva/shared_prefs # ls -al
ls -al
-rw-rw---- u0_a60 u0_a60 152 2026-04-14 14:55 jakhar.aseem.diva_preferences.xml
root@vbox86p:/data/data/jakhar.aseem.diva/shared_prefs # cat jakhar.aseem.diva_preferences.xml
at jakhar.aseem.diva_preferences.xml
<?xml version='1.0' encoding='utf-8' standalone='yes' ?>
<map>
  <string name="user">abcde</string>
  <string name="password">12345</string>
</map>
root@vbox86p:/data/data/jakhar.aseem.diva/shared_prefs #

```

Рисунок 36 – Просмотр общих настроек (2)

Уязвимость заключается в том, что для хранения конфиденциальных данных (имени пользователя и пароля) используются стандартные SharedPreferences, которые сохраняют данные в открытом виде (plain text) в XML-файле. Любой пользователь с правами root или имеющий доступ к файловой системе через ADB, может прочитать эти данные.

Рекомендация по устранению:

Необходимо использовать шифрование при хранении данных. Для этого следует использовать EncryptedSharedPreferences (из библиотеки AndroidX Security) или производить ручное шифрование данных перед записью в SharedPreferences.

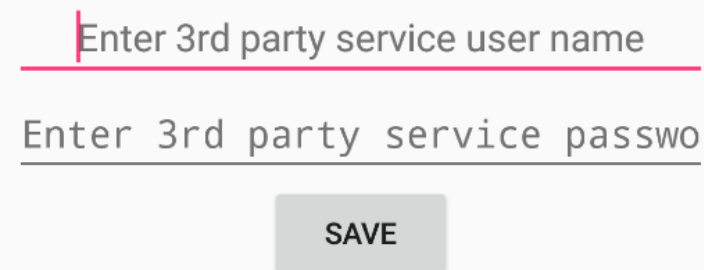
2.4 Insecure Data Storage Part 2

На рисунке 37 представлено задание.

4. Insecure Data Storage - Part 2

Objective: Find out where/how the credentials are being stored and the vulnerable code.

Hint: Insecure data storage is the result of storing confidential information insecurely on the system i.e. poor encryption, plain text, access control issues etc.



Enter 3rd party service user name

Enter 3rd party service passwo

SAVE

Рисунок 37 – Задание четвертого кейса

Цель: выяснить, где и как хранятся учетные данные, и найти уязвимый фрагмент кода.

Подсказка: небезопасное хранение данных возникает, когда конфиденциальная информация сохраняется на устройстве без должной защиты (например, слабое шифрование, хранение в открытом виде, отсутствие контроля доступа и т. д.).

Как и в предыдущие разы необходимо сначала изучить манифест (рисунок 38). Переходим к исходному коду четвертого действия (рисунок 39).



Рисунок 38 – Анализ манифеста



Рисунок 39 – Исходный код четвертого кейса

В данном кейсе осуществляется хранение данных в базе данных. И снова не используется никакое шифрование, а значит конфиденциальная информация хранится в

открытом доступе. Перед тем, как убедиться в этом, необходимо сохранить какие-нибудь данные (рисунок 40).

4. Insecure Data Storage - Part 2

Objective: Find out where/how the credentials are being stored and the vulnerable code.
Hint: Insecure data storage is the result of storing confidential information insecurely on the system i.e. poor encryption, plain text, access control issues etc.

Anastasia

...

SAVE

3rd party credentials saved successfully!

Рисунок 40 – Сохранение произвольных данных

Проверим, сможем ли мы получить к ним доступ. Весь процесс можно увидеть на рисунках 41 – 43.

```

C:\Users\Анастасия\Desktop
$ adb shell
root@vbox86p:/ # cd data/data/jakhar.aseem.diva/
cd data/data/jakhar.aseem.diva/
root@vbox86p:/data/data/jakhar.aseem.diva # ls -al
ls -al
drwxrwx--x u0_a60 u0_a60 database 2026-04-14 10:23 cache
drwxrwx--x u0_a60 u0_a60 database 2026-04-14 10:23 code_cache
drwxrwx--x u0_a60 u0_a60 database 2026-04-14 15:31 databases
lrwxrwxrwx root root database 2026-04-14 14:21 lib -> /data/app/jakhar.aseem.diva-1/lib/x86
drwxrwx--x u0_a60 u0_a60 database 2026-04-14 14:55 shared_prefs
root@vbox86p:/data/data/jakhar.aseem.diva # exit
exit

C:\Users\Анастасия\Desktop
$ adb pull /data/data/jakhar.aseem.diva/databases/
pull: building file list...
pull: /data/data/jakhar.aseem.diva/databases/ids2-journal -> ./ids2-journal
pull: /data/data/jakhar.aseem.diva/databases/ids2 -> ./ids2
pull: /data/data/jakhar.aseem.diva/databases/divanotes.db-journal -> ./divanotes.db-journal
pull: /data/data/jakhar.aseem.diva/databases/divanotes.db -> ./divanotes.db
4 files pulled. 0 files skipped.
1036 KB/s (54304 bytes in 0.051s)

```

Рисунок 41 – Получение доступа к данным (1)

```

C:\Users\Анастасия\Desktop\databases
$ ls
divanotes.db divanotes.db-journal ids2 ids2-journal

```

Рисунок 42 – Получение доступа к данным (2)

```

C:\Users\Анастасия\Desktop\databases
$ strings ids2
SQLite format 3
stablemyusermyuser
CREATE TABLE myuser(user VARCHAR, password VARCHAR)W
ctableandroid_metadataandroid_metadata
CREATE TABLE android_metadata (locale TEXT)
en_US
Anastasia123

```

Рисунок 43 – Получение доступа к данным (3)

На рисунке 43 видны склеенные данные, которые были введены. И вот она уязвимость.

2.5 Insecure Data Storage Part 3

Необходимо выполнить тоже самое, что и в предыдущих пунктах. Сперва сохраним какие-нибудь данные (рисунок 44), а затем изучим исходный код кейса (рисунок 45).

5. Insecure Data Storage - Part 3

Objective: Find out where/how the credentials are being stored and the vulnerable code.

Hint: Insecure data storage is the result of storing confidential information insecurely on the system i.e. poor encryption, plain text, access control issues etc.

The screenshot shows a web form with a text input field containing the word "Hello". Below it is a password field with five dots and a red vertical cursor line at the end. A red horizontal line is positioned below the password field. Underneath the password field is a grey button labeled "SAVE". At the bottom of the form is a dark grey rounded rectangle containing the text "3rd party credentials saved successfully!".

Рисунок 44 – Ввод данных

```

package jakhar.aseem.diva;

import android.os.Bundle;
import android.support.v7.app.AppCompatActivity;
import android.util.Log;
import android.view.View;
import android.widget.EditText;
import android.widget.Toast;
import java.io.File;
import java.io.FileWriter;

/* JADX INFO: loaded from: classes.dex */
17 public class InsecureDataStorage3Activity extends AppCompatActivity {
18     @Override // android.support.v7.app.AppCompatActivity, android.support.v4.app.FragmentActivity,
19     protected void onCreate(Bundle savedInstanceState) {
20         super.onCreate(savedInstanceState);
21         setContentView(R.layout.activity_insecure_data_storage3);
22     }

23     public void saveCredentials(View view) {
24         EditText usr = (EditText) findViewById(R.id.ids3Usr);
25         EditText pwd = (EditText) findViewById(R.id.ids3Pwd);
26         File ddir = new File(getApplicationInfo().dataDir);
27         try {
28             File uinfo = File.createTempFile("uinfo", "tmp", ddir);
29             uinfo.setReadable(true);
30             uinfo.setWritable(true);
31             FileWriter fw = new FileWriter(uinfo);
32             fw.write(usr.getText().toString() + ":" + pwd.getText().toString() + "\n");
33             fw.close();
34             Toast.makeText(this, "3rd party credentials saved successfully!", 0).show();
35         } catch (Exception e) {
36             Toast.makeText(this, "File error occurred", 0).show();
37             Log.d("Diva", "File error: " + e.getMessage());
38         }
39     }
40 }

```

Рисунок 45 – Анализа исходного кода

Теперь данные будут храниться в временном файле. Давайте посмотрим его содержимое.

```

C:\Users\Анастасия\Desktop\databases
$ adb shell
root@vbox86p:/ # cd data/data/jakhar.aseem.diva/
cd data/data/jakhar.aseem.diva/
root@vbox86p:/data/data/jakhar.aseem.diva # ls -al
ls -al
drwxrwx--x u0_a60 u0_a60 2026-04-14 10:23 cache
drwxrwx--x u0_a60 u0_a60 2026-04-14 10:23 code_cache
drwxrwx--x u0_a60 u0_a60 2026-04-14 15:31 databases
lrwxrwxrwx root root 2026-04-14 14:21 lib -> /data/app/jakhar.aseem.diva-1/lib/x86
drwxrwx--x u0_a60 u0_a60 2026-04-14 14:55 shared_prefs
-rw----- u0_a60 u0_a60 12 2026-04-14 16:06 uinfo-119075967tmp
root@vbox86p:/data/data/jakhar.aseem.diva # cat uinfo-119075967tmp
cat uinfo-119075967tmp
Hello:78910
root@vbox86p:/data/data/jakhar.aseem.diva #

```

Рисунок 46 – Получение доступа к данным

Вот и все. Мы получили данные, которые были введены, через двоеточие (рисунок 46). И снова уязвимость открытого хранения данных.

2.6 Insecure Data Storage Part 4

В этом кейсе нужно сделать тоже само, что и в двух предыдущих. Снова введем тестовые данные (рисунок 47). После сразу посмотрим исходный код (рисунок 48). Можно уже предположить, что на этот раз данные будут храниться на каком-то внешнем хранилище.

6. Insecure Data Storage - Part 4

Objective: Find out where/how the credentials are being stored and the vulnerable code.
Hint: Insecure data storage is the result of storing confidential information insecurely on the system i.e. poor encryption, plain text, access control issues etc.

dsgdjfhgjk

.....

SAVE

File error occurred

Рисунок 47 – Ошибка сохранения данных

```
AndroidManifest.xml x InsecureDataStorage4Activity x
package jakhar.aseem.diva;

import android.os.Bundle;
import android.os.Environment;
import android.support.v7.app.AppCompatActivity;
import android.util.Log;
import android.view.View;
import android.widget.EditText;
import android.widget.Toast;
import java.io.File;
import java.io.FileWriter;

/* JADX INFO: loaded from: classes.dex */
16 public class InsecureDataStorage4Activity extends AppCompatActivity {
17     @Override // android.support.v7.app.AppCompatActivity, android.support.v4.app.FragmentA
18     protected void onCreate(Bundle savedInstanceState) {
19         super.onCreate(savedInstanceState);
20         setContentView(R.layout.activity_insecure_data_storage4);
21     }

22     public void saveCredentials(View view) {
23         EditText usr = (EditText) findViewById(R.id.ids4Usr);
24         EditText pwd = (EditText) findViewById(R.id.ids4Pwd);
25         File sdir = Environment.getExternalStorageDirectory();
26         try {
27             File uinfo = new File(sdir.getAbsolutePath() + "/.uinfo.txt");
28             uinfo.setReadable(true);
29             uinfo.setWritable(true);
30             FileWriter fw = new FileWriter(uinfo);
31             fw.write(usr.getText().toString() + ":" + pwd.getText().toString() + "\n");
32             fw.close();
33             Toast.makeText(this, "3rd party credentials saved successfully!", 0).show();
34         } catch (Exception e) {
35             Toast.makeText(this, "File error occurred", 0).show();
36             Log.d("Diva", "File error: " + e.getMessage());
37         }
38     }
39 }
40 }
```

Рисунок 48 – Исходный код данного кейса

Сохранение будет производиться в файл на внешнем хранилище, гипотеза подтвердилась. Необходимо разрешение на доступ к внешнему хранилищу. Необходимо перейти в настройки и разрешить (рисунок 49). Теперь снова пробуем сохранить данные (рисунок 50).

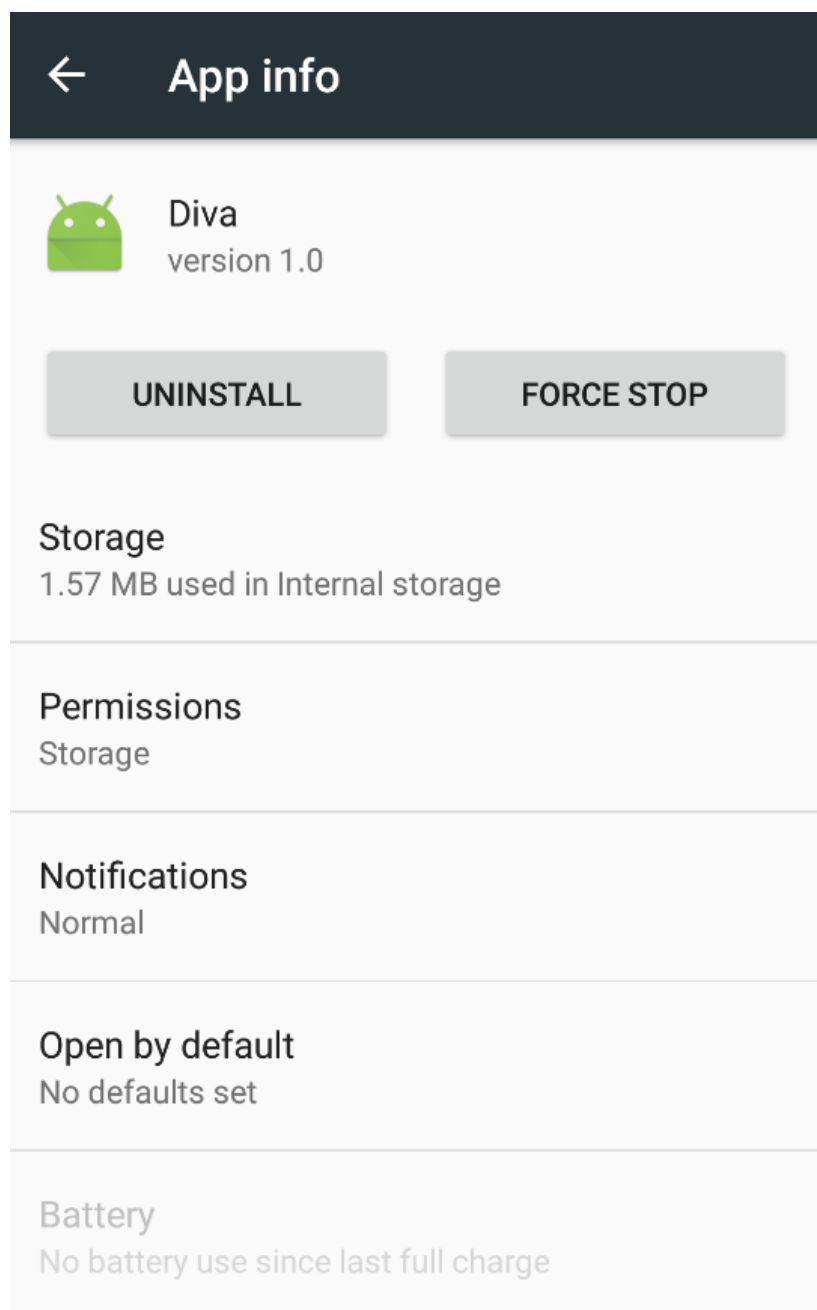
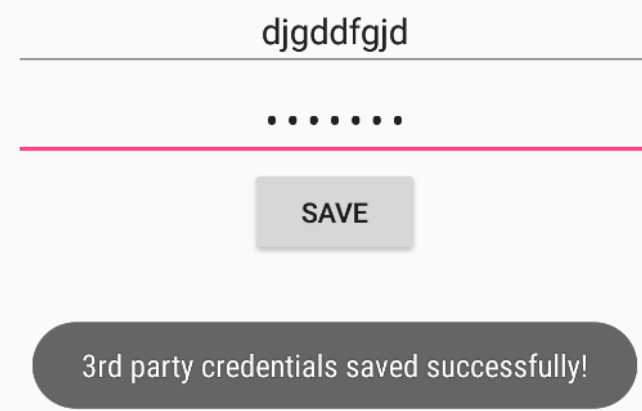


Рисунок 49 – Делаем Permissions Storage

6. Insecure Data Storage - Part 4

Objective: Find out where/how the credentials are being stored and the vulnerable code.

Hint: Insecure data storage is the result of storing confidential information insecurely on the system i.e. poor encryption, plain text, access control issues etc.



The screenshot shows a web form with two input fields. The first field contains the text 'djgddfgjd'. The second field contains seven dots, indicating a password. Below the fields is a grey 'SAVE' button. At the bottom, a dark grey rounded rectangle contains the message '3rd party credentials saved successfully!'.

djgddfgjd

.....

SAVE

3rd party credentials saved successfully!

Рисунок 50 – Успешное сохранение данных

```

C:\Users\Анастасия\Desktop\databases
$ adb shell
root@vbox86p:/ # cd /mnt/
cd /mnt/
root@vbox86p:/mnt # ls -al
ls -al
drwxr-xr-x root      system      2026-04-14 14:21 asec
drwxrwx--x system    system      2026-04-14 14:21 expand
drwxr-x--- root      media_rw    2026-04-14 14:21 media_rw
drwxr-xr-x root      system      2026-04-14 14:21 obb
drwx----- root      root        2026-04-14 14:21 runtime
lrwxrwxrwx root      root        2026-04-14 14:21 sdcard -> /sdcard
drwx----- root      root        2026-04-14 14:21 secure
drwxrwxrwx root      root        2026-04-14 09:22 shared
drwxr-xr-x root      root        2026-04-14 14:21 user
root@vbox86p:/mnt # cd sdcard
cd sdcard
root@vbox86p:/mnt/sdcard # ls -al
ls -al
-rw-rw---- root      sdcard_rw    18 2026-04-14 16:23 .uinfo.txt
drwxrwx--x root      sdcard_rw    2026-04-14 09:27 Alarms
drwxrwx--x root      sdcard_rw    2026-04-14 09:27 DCIM
drwxrwx--x root      sdcard_rw    2026-04-14 09:27 Download
drwxrwx--x root      sdcard_rw    2026-04-14 09:27 Movies
drwxrwx--x root      sdcard_rw    2026-04-14 09:27 Music
drwxrwx--x root      sdcard_rw    2026-04-14 09:27 Notifications
drwxrwx--x root      sdcard_rw    2026-04-14 09:27 Pictures

```

Рисунок 51 – Получение данных (1)

```

root@vbox86p:/mnt/sdcard # cat .uinfo.txt
cat .uinfo.txt
djgddfgjd:6545213
root@vbox86p:/mnt/sdcard # |

```

Рисунок 52 – Получение данных (2)

И снова наши данные у всех на виду.

2.7 Improper Input Validation Part 1

7. Input Validation Issues - Part 1

Objective: Try to access all user data without knowing any user name. There are three users by default and your task is to output data of all the three users with a single malicious search.

Hint: Improper or no input validation issue arise when the input is not filtered or validated before using it. When developing components that take input from outside, always validate it. For ease of testing there are three users already present in the database, for example one of them is admin, you can try searching for admin to test the output.

Enter user name to search

SEARCH

Рисунок 53 – Задание

```
AndroidManifest.xml x SQLInjectionActivity x

package jakhar.aseem.diva;

import android.database.Cursor;
import android.database.sqlite.SQLiteDatabase;
import android.os.Bundle;
import android.support.v7.app.AppCompatActivity;
import android.util.Log;
import android.view.View;
import android.widget.EditText;
import android.widget.Toast;

/* JADX INFO: loaded from: classes.dex */
16 public class SQLInjectionActivity extends AppCompatActivity {
    private SQLiteDatabase mDB;

    @Override // android.support.v7.app.AppCompatActivity, android.support.v4.app.FragmentActivity, android.support.v4.app.BaseFragmentActivityD
17 protected void onCreate(Bundle savedInstanceState) {
18     super.onCreate(savedInstanceState);
21     try {
22         this.mDB = openOrCreateDatabase("sqli", 0, null);
23         this.mDB.execSQL("DROP TABLE IF EXISTS sqliuser;");
24         this.mDB.execSQL("CREATE TABLE IF NOT EXISTS sqliuser(user VARCHAR, password VARCHAR, credit_card VARCHAR);");
25         this.mDB.execSQL("INSERT INTO sqliuser VALUES ('admin', 'passwd123', '1234567812345678');");
26         this.mDB.execSQL("INSERT INTO sqliuser VALUES ('diva', 'p@ssword', '1111222233334444');");
27         this.mDB.execSQL("INSERT INTO sqliuser VALUES ('john', 'password123', '5555666677778888');");
28     } catch (Exception e) {
29         Log.d("Diva-sqli", "Error occurred while creating database for SQLI: " + e.getMessage());
30     }
31     setContentView(R.layout.activity_sqlinjection);
32 }

35 public void search(View view) {
36     EditText srchtxt = (EditText) findViewById(R.id.iv1search);
37     try {
38         Cursor cr = this.mDB.rawQuery("SELECT * FROM sqliuser WHERE user = '" + srchtxt.getText().toString() + "'", null);
39         StringBuilder strb = new StringBuilder("");
40         if (cr != null && cr.getCount() > 0) {
41             cr.moveToFirst();
42             do {
43                 strb.append("User: (" + cr.getString(0) + ") pass: (" + cr.getString(1) + ") Credit card: (" + cr.getString(2) + ")\n");
44             } while (cr.moveToNext());
45         } else {
46             strb.append("User: (" + srchtxt.getText().toString() + ") not found");
47         }
48         Toast.makeText(this, strb.toString(), 0).show();
49     } catch (Exception e) {
50         Log.d("Diva-sqli", "Error occurred while searching in database: " + e.getMessage());
51     }
52 }
53 }
```

Рисунок 54 – Исходный код

7. Input Validation Issues - Part 1

Objective: Try to access all user data without knowing any user name. There are three users by default and your task is to output data of all the three users with a single malicious search.

Hint: Improper or no input validation issue arise when the input is not filtered or validated before using it. When developing components that take input from outside, always validate it. For ease of testing there are three users already present in the database, for example one of them is admin, you can try searching for admin to test the output.

admin

SEARCH

User: (admin) pass: (passwd123) Credit
card: (1234567812345678)

Рисунок 55 – Тестовые данные

7. Input Validation Issues - Part 1

Objective: Try to access all user data without knowing any user name. There are three users by default and your task is to output data of all the three users with a single malicious search.

Hint: Improper or no input validation issue arise when the input is not filtered or validated before using it. When developing components that take input from outside, always validate it. For ease of testing there are three users already present in the database, for example one of them is admin, you can try searching for admin to test the output.

admin' or '1'='1|

SEARCH

User: (admin) pass: (passwd123) Credit card: (1234567812345678)
User: (diva) pass: (p@ssword) Credit card: (1111222233334444)
User: (john) pass: (password123) Credit card: (5555666677778888)

Рисунок 56 – Вывод всех пользователей системы

Классическая SQL-инъекция – уязвимость системы. Получаем доступ к ресурсам.

2.8 Improper Input Validation Part 2

8. Input Validation Issues - Part 2

Objective: Try accessing any sensitive information apart from a web URL.

Hint: Improper or no input validation issue arise when the input is not filtered or validated before using it. When developing components that take input from outside, always validate it.

Enter the URL to view

VIEW

Рисунок 57 – Задание

```
AndroidManifest.xml x InputValidation2URISchemeAc... x
package jakhar.aseem.diva;

import android.os.Bundle;
import android.support.v7.app.AppCompatActivity;
import android.view.View;
import android.webkit.WebSettings;
import android.webkit.WebView;
import android.widget.EditText;

/* JADX INFO: loaded from: classes.dex */
12 public class InputValidation2URISchemeActivity extends AppCompatActivity {
13     @Override // android.support.v7.app.AppCompatActivity, android.support.v4.app.Fragment
14     protected void onCreate(Bundle savedInstanceState) {
15         super.onCreate(savedInstanceState);
16         setContentView(R.layout.activity_input_validation2_urischeme);
17         WebView wview = (WebView) findViewById(R.id.ivi2wview);
18         WebSettings wset = wview.getSettings();
19         wset.setJavaScriptEnabled(true);
20     }

23     public void get(View view) {
24         EditText uriText = (EditText) findViewById(R.id.ivi2uri);
25         WebView wview = (WebView) findViewById(R.id.ivi2wview);
26         wview.loadUrl(uriText.getText().toString());
27     }
28 }
```

Рисунок 58 – Исходный код

Для доступа к конфиденциальным данным попробуем использовать метод file.

8. Input Validation Issues - Part 2

Objective: Try accessing any sensitive information apart from a web URL.

Hint: Improper or no input validation issue arise when the input is not filtered or validated before using it. When developing components that take input from outside, always validate it.

file:///sdcard/.uinfo.txt

VIEW

djgddfjgd:6545213

Рисунок 59 – Уязвимость

8. Input Validation Issues - Part 2

Objective: Try accessing any sensitive information apart from a web URL.

Hint: Improper or no input validation issue arise when the input is not filtered or validated before using it. When developing components that take input from outside, always validate it.

jakhar.aseem.diva/uinfo-119075967tmp

VIEW

Hello:78910

Рисунок 60 – Доступ к конфиденциальной информации

2.9 Access Control Issue Part 1

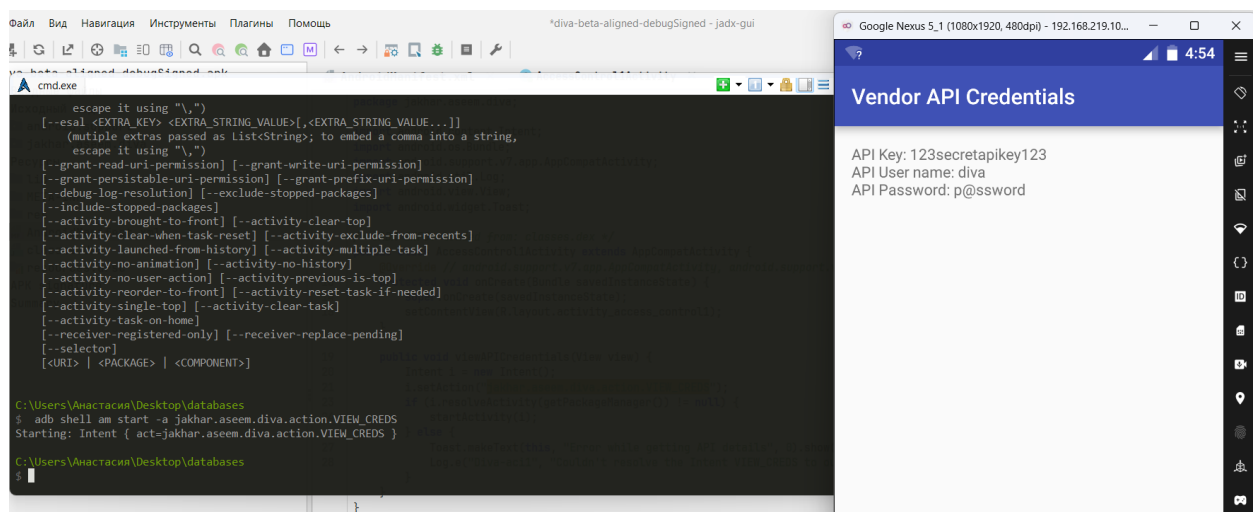


Рисунок 61 – Получили доступ к данным, не нажимая кнопку

Можно вызвать внутренние компоненты, только если все действия были экспортированы, а по умолчанию они экспортируются. Это нужно самостоятельно защищать.

- 2.10 Access Control Issue part 2**
- 2.11 Access Control Issue Part 3**
- 2.12 Hardcoding Issue Part 2**
- 2.13 Input Validation Issue Part 3**

ЗАКЛЮЧЕНИЕ

В ходе выполнения лабораторной работы была успешно достигнута основная цель: приобретены практические навыки анализа защищенности мобильных приложений на платформе Android. Был развернут и настроен полноценный тестовый стенд для пентестинга, включающий эмулятор Genymotion, инструментарий Appie (ADB, JADX, ArkTool) и специальное учебное приложение Diva Android. Настройка окружения позволила отработать базовое взаимодействие между хост-системой и виртуальным устройством, а также закрепить навыки работы с Android Debug Bridge для управления пакетами, сбора логов и доступа к файловой системе эмулятора.

В процессе исследования приложения Diva были практически изучены типичные уязвимости, входящие в модель OWASP Mobile Top 10. Методами статического анализа кода в JADX и динамического мониторинга через adb logcat были выявлены критические недостатки реализации: хранение конфиденциальных данных в открытом виде в SharedPreferences и локальных базах данных SQLite, небезопасное логирование чувствительной информации (например, номеров платежных карт), использование захардкоженных ключей доступа, а также уязвимость к SQL-инъекциям, позволяющая обходить аутентификацию и извлекать данные всех пользователей одним запросом. Каждый кейс был успешно воспроизведен, что подтвердило теоретические положения о рисках мобильной разработки.

Полученный опыт продемонстрировал, что большинство уязвимостей мобильных приложений связаны с пренебрежением базовыми стандартами безопасности на этапе разработки: отсутствием шифрования локальных данных, недостаточной валидацией пользовательского ввода и излишней детализацией отладочных логов в релизных сборках. Лабораторная работа позволила закрепить навыки декомпиляции APK-файлов, поиска уязвимых фрагментов кода, анализа файловых хранилищ и перехвата системных событий. Эти компетенции являются фундаментальными для дальнейшего изучения мобильной кибербезопасности и проведения профессионального аудита защищенности Android-приложений.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. <https://github.com/ProjectAppie/downloads/releases/tag/v3.1>
2. <https://github.com/tjunxiang92/Android-Vulnerabilities/blob/master/diva-beta.apk>
3. <https://github.com/patrickfav/uber-apk-signer/releases>
4. <https://www.java.com/ru/download/>
5. <http://github.com/skylot/jadx/releases/tag/v1.5.5>
- 6.